



Université de Monastir
Faculté des Sciences de Monastir
Département Informatique

Rapport de stage

Conception et mise en œuvre d'une solution SIEM Cloud-Native basée sur Azure Monitor et Microsoft Sentinel chez SMARTOVATE LTD



Réalisé par :
Wala Hassine

Encadrant professionnel :
M. Abdelkhalek Bakkari

Année universitaire : 2025–2026

Résumé

Le présent rapport rend compte d'un stage de deux mois (juin-juillet 2026) effectué au sein de SMARTOVATE LTD, consacré à la conception et au déploiement d'une solution SIEM Cloud-Native reposant sur Azure Monitor et Microsoft Sentinel.

Face à l'élargissement de la surface d'attaque induit par l'adoption massive des architectures cloud, l'objectif du projet était de mettre en place une infrastructure de supervision de sécurité centralisée, capable de détecter des anomalies en temps réel, de les visualiser via des tableaux de bord interactifs, et d'automatiser la réponse aux incidents fréquents.

Le travail a couvert quatre axes fonctionnels organisés en Epics au sein d'un backlog Jira : la centralisation des journaux via un espace de travail Log Analytics, l'activation de Microsoft Sentinel et la connexion des sources de données natives Microsoft, le développement de règles de détection en langage KQL, la conception de Workbooks de visualisation, et enfin l'automatisation de la réponse aux incidents via des Playbooks SOAR construits avec Azure Logic Apps.

La démarche a été conduite selon une approche agile, avec un suivi structuré des tâches, une architecture justifiée par une analyse comparative des technologies disponibles, une estimation budgétaire des ressources Azure consommées, et une vérification de la conformité de l'architecture aux exigences de la norme ISO/IEC 27001 :2022.

Ce rapport détaille le contexte, l'analyse des besoins, la conception, la réalisation et l'évaluation de conformité de cette solution, réalisée intégralement dans un environnement Azure de test.

Mots-clés : SIEM, Cloud-Native, Azure Monitor, Microsoft Sentinel, SOAR, KQL, Log Analytics, ISO/IEC 27001, SOC, Automatisation de la sécurité.

Abstract

This report presents the outcome of a two-month internship (June–July 2026) carried out at SMARTOVATE LTD, focused on the design and deployment of a Cloud-Native SIEM solution built on Azure Monitor and Microsoft Sentinel.

In response to the expanding attack surface driven by widespread cloud adoption, the project aimed to build a centralized security monitoring infrastructure capable of detecting anomalies in real time, visualizing the organization’s security posture through interactive dashboards, and automating the response to recurring security incidents.

The work was structured around four functional axes organized as Epics in a Jira backlog : centralizing event logs through a Log Analytics workspace, activating Microsoft Sentinel and connecting native Microsoft data sources, developing KQL-based detection rules, designing visualization Workbooks, and automating incident response through SOAR Playbooks built with Azure Logic Apps. The approach followed an agile methodology, with structured task tracking, an architecture justified through a comparative technology analysis, a cost estimation of the Azure resources consumed, and a compliance assessment of the architecture against the ISO/IEC 27001 :2022 standard.

This report details the context, requirements analysis, design, implementation, and compliance evaluation of this solution, entirely carried out within an Azure sandbox environment.

Keywords : SIEM, Cloud-Native, Azure Monitor, Microsoft Sentinel, SOAR, KQL, Log Analytics, ISO/IEC 27001, SOC, Security Automation.

Table des matières

Résumé	i
Abstract	ii
Table des matières	iii
Table des figures	vi
Liste des tableaux	vii
Liste des abréviations	viii
Introduction générale	1
1 Contexte général du projet	2
1.1 Présentation de l'organisme d'accueil : SMARTOVATE LTD	2
1.2 Contexte et problématique du projet	2
1.2.1 Élargissement de la surface d'attaque cloud	2
1.2.2 Limites de la sécurité périmétrique traditionnelle	3
1.3 Objectifs du projet	3
1.4 Périmètre du projet	4
1.4.1 Éléments inclus	4

1.4.2	Éléments exclus	5
1.5	Méthodologie de conduite de projet	5
1.6	Planning prévisionnel	6
2	Analyse et spécification des besoins	7
2.1	Identification des acteurs	7
2.2	Spécifications fonctionnelles	8
2.2.1	Tableau récapitulatif des exigences	8
2.2.2	Fiches détaillées des exigences	9
2.3	Spécifications non fonctionnelles	10
2.4	Contraintes techniques	11
2.5	Backlog produit	11
2.5.1	Epic 1 — Mise en place de l’infrastructure de base et collecte des logs	11
2.5.2	Epic 2 — Développement des capacités de détection (SIEM)	12
2.5.3	Epic 3 — Visualisation et Reporting (Workbooks)	12
2.5.4	Epic 4 — Automatisation de la réponse aux incidents (SOAR)	13
2.6	Analyse des risques et bugs anticipés	13
3	Conception et choix technologiques	14
3.1	Vue d’ensemble de l’architecture cloud-native	14
3.2	Justification des choix technologiques	15
3.3	Modélisation UML du système	17
3.3.1	Diagrammes de cas d’utilisation	17
3.3.2	Diagrammes de classes et modèle de domaine	20
3.3.3	Diagrammes de séquence	23

3.3.4	Architecture C4 et diagramme de composants	27
3.4	Estimation des coûts des ressources Azure	28
3.4.1	Hypothèses et paramètres d'estimation	28
3.4.2	Détail des coûts par service	28
4	Conformité, sécurité et évaluation	30
4.1	Présentation de la norme ISO/IEC 27001 :2022	30
4.2	Contrôles ISO pertinents pour le projet SIEM Cloud-Native avec Azure Monitor & Sentinel	31
4.3	Cartographie ISO 27001 et architecture	33
4.4	Bilan de conformité et recommandations d'amélioration	35
	Bibliographie	38
	Bibliographie	38
A	Requêtes KQL intégrales	39
A.1	SIEM-3 — Création de l'espace de travail Log Analytics	39
A.2	SIEM-4 — Activation de Sentinel et connexion des sources natives	39
A.3	SIEM-5 / SIEM-6 — Détection des connexions suspectes	40
A.4	SIEM-7 — Détection de l'élévation de privilèges	42
A.5	SIEM-8 — Workbook Dashboard de sécurité Azure Activity	44
A.6	SIEM-9 — Playbook SOAR : Notification Slack sur incident High	47
B	Glossaire technique	48

Table des figures

1.1	Logo de SMARTOVATE LTD	2
3.1	UCd-01 — Cas d'utilisation de l'Epic 1 : Infrastructure et collecte	18
3.2	UCd-02 — Cas d'utilisation de l'Epic 2 : Détection SIEM	18
3.3	UCd-03 — Cas d'utilisation de l'Epic 3 : Visualisation avec Workbooks	19
3.4	UCd-04 — Cas d'utilisation de l'Epic 4 : Automatisation SOAR	19
3.5	CLD-01 — Modèle de domaine de la couche infrastructure	20
3.6	CLD-02 — Modèle de domaine de la couche détection	21
3.7	CLD-03 — Modèle de domaine de la couche visualisation	21
3.8	CLD-04 — Modèle de domaine de la couche automatisation SOAR	22
3.9	SEQ-01 — Séquence de détection d'une connexion suspecte par IP malveillante . . .	23
3.10	SEQ-02 — Séquence de détection d'une élévation de privilèges	24
3.11	SEQ-03 — Séquence de notification automatique Teams par Playbook SOAR	25
3.12	SEQ-04 — Séquence de remédiation par désactivation de compte compromis	26
3.13	IO-02 — Diagramme de composants et architecture C4 Container du SIEM Cloud-Native	27

Liste des tableaux

1.2	Planning prévisionnel du stage sur huit semaines	6
2.1	Parties prenantes et acteurs du système SIEM	7
2.2	Synthèse des exigences fonctionnelles	8
2.3	Fiches détaillées des exigences fonctionnelles	10
2.4	Exigences non fonctionnelles	10
2.5	Contraintes techniques du projet	11
2.6	Risques et bugs anticipés	13
3.1	Vue d'ensemble de l'architecture SIEM Cloud-Native	15
3.2	Synthèse des choix technologiques retenus	16
3.3	Hypothèses retenues pour l'estimation des coûts Azure	28
3.4	Estimation des coûts mensuels des ressources Azure	29
4.1	Cartographie des composants SIEM et contrôles ISO/IEC 27001 :2022	33
4.2	Cartographie des composants SIEM et contrôles ISO/IEC 27001 :2022 (suite)	34
B.1	Glossaire technique du projet SIEM Cloud-Native	49

Liste des abréviations

Abréviation	Signification
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
KQL	Kusto Query Language
RBAC	Role-Based Access Control
IAM	Identity and Access Management
AD	Active Directory
Entra ID	Microsoft Entra ID (anciennement Azure Active Directory)
API	Application Programming Interface
IaC	Infrastructure as Code
MTTD	Mean Time To Detect
MTTR	Mean Time To Respond / Resolve
KPI	Key Performance Indicator
PME	Petite et Moyenne Entreprise
US	User Story
UML	Unified Modeling Language
C4	Context, Containers, Components, Code (modèle d'architecture)
ISO/IEC	International Organization for Standardization / International Electrotechnical Commission
SMSI	Système de Management de la Sécurité de l'Information
MMA	Microsoft Monitoring Agent
VM	Virtual Machine (machine virtuelle)
TI	Threat Intelligence
UEBA	User and Entity Behavior Analytics

Introduction générale

Le développement rapide des **infrastructures cloud** a transformé en profondeur la manière dont les organisations gèrent, exposent et sécurisent leurs données. Cette transformation s'accompagne d'un changement de paradigme dans la **posture de sécurité** des entreprises : les **frontières réseau** se dissolvent, les **identités** deviennent la nouvelle unité de contrôle, et les volumes de **journaux** à superviser croissent de façon continue. Le paysage des menaces suit cette évolution : les acquisitions dans le cloud sont devenues une cible de choix, près de 80 % des organisations ayant déclaré au moins un incident de sécurité lié au cloud au cours des douze derniers mois, et les intrusions dites « **cloud-conscious** » ont progressé de 37 % sur la seule année 2025 selon le dernier rapport CrowdStrike. Ce contexte impose aux entreprises de dépasser les outils de **sécurité périmétrique** traditionnels au profit de solutions natives, évolutives, et étroitement intégrées à leur fournisseur cloud.

C'est dans cette dynamique que s'inscrit le stage réalisé au sein de **SMARTOVATE LTD**, entreprise active dans le conseil et les solutions cloud et intelligence artificielle. D'une durée de deux mois, ce stage avait pour finalité la conception et le déploiement d'une solution **SIEM Cloud-Native** reposant sur l'écosystème **Microsoft Azure**, en particulier **Azure Monitor** pour la collecte des **journaux** et **Microsoft Sentinel** comme moteur **SIEM** et **SOAR**. L'ambition du projet n'était pas de réagir après-coup à des incidents, mais de construire, dès la conception, une chaîne complète allant de la **collecte des données** jusqu'à la **remédiation automatisée**, en passant par la **détection intelligente** et la **visualisation opérationnelle**.

La **problématique centrale** de ce travail peut se formuler ainsi : comment concevoir, dans un délai contraint de deux mois et dans un environnement de test, une architecture de supervision de sécurité qui soit à la fois techniquement fonctionnelle, économiquement soutenable, et alignée avec les exigences d'un référentiel de sécurité reconnu tel que l'**ISO/IEC 27001 :2022** ?

Répondre à cette question suppose de mener de front une analyse des **besoins fonctionnels et non fonctionnels**, une étude comparative des **choix technologiques** disponibles sur le marché, une **modélisation** rigoureuse du système, une implémentation itérative suivie via une **méthodologie agile**, puis une **évaluation de conformité**.

Ce rapport s'organise en quatre chapitres. Le premier chapitre présente le contexte général du projet, l'organisme d'accueil, la problématique, le périmètre retenu ainsi que la méthodologie et le planning adoptés. Le deuxième chapitre détaille l'analyse et la spécification des **besoins fonctionnels et non fonctionnels**. Le troisième chapitre expose la conception de l'architecture, les **choix technologiques** justifiés et la **modélisation** UML du système. Enfin, le quatrième chapitre évalue la conformité de l'architecture à la norme **ISO/IEC 27001 :2022**.

Chapitre 1

Contexte général du projet

1.1 Présentation de l'organisme d'accueil : SMARTOVATE LTD

SMARTOVATE LTD est une société immatriculée au Royaume-Uni sous le numéro d'enregistrement **15865802** auprès du *Companies House* britannique. L'entreprise est dirigée par **Abdelkhalek Bakkari**, fondateur et CEO, de nationalité tunisienne, qui occupe les fonctions de *Director* au sein de la société. Son siège administratif est basé à Londres.

SMARTOVATE LTD se positionne comme un acteur du conseil et du développement de solutions cloud et d'intelligence artificielle, avec un double positionnement observé sur ses supports publics : d'une part l'édition de solutions logicielles orientées automatisation des processus métier et productivité des équipes, et d'autre part l'accompagnement d'entreprises dans la prise en main des plateformes cloud Microsoft Azure et AWS, notamment pour la mise en place, la gestion et la formation.



FIGURE 1.1 – Logo de SMARTOVATE LTD

1.2 Contexte et problématique du projet

1.2.1 Élargissement de la surface d'attaque cloud

L'adoption croissante des **architectures cloud** a considérablement élargi la **surface d'attaque** des entreprises, tel que le souligne le cahier des charges du projet : les **journaux**, **identités** et

charges de travail ne résident plus dans un périmètre unique et maîtrisé, mais sont distribués entre plusieurs services, régions et fournisseurs.

Cette observation, propre au contexte du projet, rejoint les constats du secteur : à mesure que les entreprises migrent vers des écosystèmes **multi-cloud** et **SaaS**, leur surface d'attaque s'est considérablement élargie, les acteurs malveillants exploitant en priorité les **mauvaises configurations**, les **API non sécurisées** et les **identités compromises**.

Cette tendance est confirmée par les données les plus récentes : plus de **94 % des entreprises** ont connu au moins un incident de sécurité cloud en 2025, soit une hausse de **14 %** par rapport à 2023, et près d'une cyberattaque sur deux implique désormais directement ou indirectement un **environnement cloud**.

Les **identités** constituent le vecteur de compromission dominant : les attaques liées à l'identité représentent **61 % des compromissions cloud confirmées en 2025**, ce qui justifie directement l'attention portée, dans le projet, à la surveillance d'**Azure Active Directory (Entra ID)** et à l'automatisation de la **révocation d'accès**.

1.2.2 Limites de la sécurité périmétrique traditionnelle

Les approches traditionnelles de **sécurité périmétrique**, fondées sur l'idée d'une **frontière réseau** claire séparant un intérieur « de confiance » d'un extérieur « hostile », ne suffisent plus à détecter et à répondre aux **menaces avancées** propres aux **environnements cloud**.

Le référentiel **NIST SP 800-207**, qui fait aujourd'hui autorité en matière d'**architecture de confiance zéro**, formalise ce constat : la sécurité réseau fondée sur le périmètre s'est révélée insuffisante, car une fois ce périmètre franchi, les **mouvements latéraux** de l'attaquant ne rencontrent plus d'obstacle.

Dans un environnement cloud où les **ressources**, les **utilisateurs** et les **appareils** ne sont plus localisés dans un réseau d'entreprise unique, le modèle de **confiance zéro** part du principe qu'aucune confiance implicite n'est accordée à un actif ou un compte utilisateur du seul fait de sa localisation réseau ou de sa propriété.

C'est précisément cette limite que le projet **SIEM Cloud-Native** cherche à combler : plutôt que de reposer sur un **pare-feu périmétrique**, l'architecture retenue centralise la **collecte de journaux** issus de multiples sources (identité, activité, pare-feux, machines virtuelles, Office 365) afin de reconstituer une **visibilité transversale**, et s'appuie sur une **gestion des identités et des accès** (RBAC, Managed Identity) plutôt que sur une simple frontière réseau.

1.3 Objectifs du projet

Le projet doit atteindre les cinq objectifs suivants dans un délai de deux mois :

ID	Description
OBJ-01	Déployer et configurer un espace de travail Log Analytics pour centraliser les journaux d'événements.
OBJ-02	Connecter les sources de données Azure natives (Azure AD , Office 365 , VMs , pare-feux) à Azure Sentinel .
OBJ-03	Créer des Analytics Rules générant des alertes basées sur des scénarios de menaces identifiés.
OBJ-04	Développer des Workbooks interactifs pour la visualisation de la posture de sécurité.
OBJ-05	Concevoir et implémenter des Playbooks SOAR via Azure Logic Apps pour automatiser la réponse aux incidents.

1.4 Périmètre du projet

Cette section délimite les activités couvertes par le projet ainsi que les aspects volontairement exclus afin de respecter les contraintes de temps, de ressources et d'environnement de test.

1.4.1 Éléments inclus

Éléments inclus

Les éléments suivants sont inclus dans le périmètre du projet :

- Configuration d'**Azure Monitor** et du **Log Analytics Workspace**.
- Activation d'**Azure Sentinel** et intégration des connecteurs de données natifs Microsoft.
- Création de **5 à 10 règles de détection personnalisées en KQL**.
- Création de **2 Workbooks** : vue d'ensemble sécurité et analyse des identités.
- Développement de **2 Playbooks SOAR** : notification Teams/Email et blocage de compte Azure AD.
- Documentation technique et guide d'exploitation.

1.4.2 Éléments exclus

Éléments exclus

Les éléments suivants sont exclus du périmètre du projet :

- Intégration de sources **on-premise** nécessitant des agents non standards.
- Développement de connecteurs personnalisés via **API REST** pour des solutions tierces non supportées nativement.
- Gestion de la facturation et optimisation avancée des coûts.
- Réponse aux incidents réels en environnement de production.

1.5 Méthodologie de conduite de projet

Le pilotage du stage a été structuré selon une démarche agile adaptée à un contexte de travail **individuel encadré**. Le référentiel méthodologique retenu comme base est le cadre Scrum, dont la définition de référence précise qu'il s'agit d'un cadre de travail léger destiné à aider des individus, des équipes et des organisations à générer de la valeur au moyen de solutions adaptatives à des problèmes complexes,

Adaptation de Scrum au contexte du stage

Le stage n'a pas reproduit l'intégralité des cérémonies d'une équipe Scrum complète, le travail étant mené par un stagiaire unique. L'approche retenue s'est concentrée sur les pratiques les plus utiles pour un projet technique court :

- découpage du besoin en unités hiérarchisées, des **Epics** vers les **User Stories** ;
- définition de **critères d'acceptation vérifiables** pour chaque exigence ;
- suivi itératif de l'avancement dans un **outil de gestion de projet dédié**.

Découpage du backlog

Le besoin exprimé dans le cahier des charges a été décomposé en quatre **Epics**, correspondant chacun à une couche fonctionnelle de l'architecture cible :

Epic	Description
Epic 1 — Infrastructure et collecte	Mise en place de l'espace de travail Log Analytics et connexion des sources de données.
Epic 2 — Détection (SIEM)	Conception et test des règles d'analyse en KQL .
Epic 3 — Visualisation	Construction des Workbooks de reporting.
Epic 4 — Automatisation (SOAR)	Développement des Playbooks de réponse aux incidents.

1.6 Planning prévisionnel

Le stage s'est déroulé sur une période de huit semaines, de juin à juillet 2026. Il a été structuré en quatre phases successives, chacune alignée sur l'avancement du backlog produit présenté dans la section précédente.

Semaine(s)	Phase	Objectifs et activités principales	Epic(s) concerné(s)
S1–S2	Cadrage et mise en place de l'infrastructure	Prise en main de l'environnement Azure et de Microsoft Sentinel ; création de l'espace de travail Log Analytics ; configuration du RBAC.	Epic 1
S3–S4	Collecte de données et visualisation initiale	Activation des connecteurs de données, notamment Azure AD et le journal d'activité Azure ; conception des premiers Workbooks.	Epic 1 / Epic 3
S5–S6	Détection et gestion des alertes	Développement et test des règles de détection KQL ; configuration des Analytics Rules et affinage des Workbooks.	Epic 2 / Epic 3
S7–S8	Automatisation SOAR	Conception et déploiement des Playbooks avec Azure Logic Apps ; tests d'intégration de bout en bout, de la détection à la remédiation.	Epic 4

TABLE 1.2 – Planning prévisionnel du stage sur huit semaines

Chapitre 2

Analyse et spécification des besoins

2.1 Identification des acteurs

L'analyse des acteurs est issue du document de conception initiale du projet. Elle distingue les acteurs humains qui utilisent ou administrent la solution, et les acteurs techniques qui participent automatiquement au fonctionnement du SIEM Cloud-Native.

Acteur	Rôle dans le projet
Administrateur sécurité	Déploie et configure l'infrastructure Azure Sentinel, le workspace Log Analytics, les connecteurs de données et les permissions RBAC.
Analyste SOC	Traite quotidiennement les incidents, analyse les alertes générées par Microsoft Sentinel et déclenche les Playbooks SOAR lorsque cela est nécessaire.
Responsable sécurité	Consulte les Workbooks afin d'évaluer la posture de sécurité, suivre les indicateurs de supervision et appuyer les décisions de pilotage.
Azure Sentinel	Joue le rôle de moteur SIEM : analyse des journaux, corrélation des événements, génération des alertes et gestion du cycle de vie des incidents.
Azure Logic Apps	Orchestre les Playbooks SOAR associés à Sentinel, notamment la notification automatique et la remédiation par désactivation de compte compromis.

TABLE 2.1 – Parties prenantes et acteurs du système SIEM

2.2 Spécifications fonctionnelles

Les spécifications fonctionnelles formalisent les services attendus du SIEM Cloud-Native. Elles couvrent trois domaines principaux : la collecte centralisée des journaux, la détection automatique des menaces et l'automatisation de la réponse aux incidents.

2.2.1 Tableau récapitulatif des exigences

ID	Intitulé	Priorité	Objectif couvert
EF-01	Centralisation des journaux d'événements	Must Have	Créer et configurer un workspace Log Analytics unique avec rétention et accès sécurisés.
EF-02	Connexion des sources Microsoft natives	Must Have	Activer Sentinel et connecter Azure AD, Azure Activity, Office 365, VMs et pare-feux Azure.
EF-03	Détection des connexions suspectes	Must Have	Identifier les connexions issues d'IP malveillantes ou de pays inhabituels.
EF-04	Détection des élévations de privilèges	Must Have	Surveiller les ajouts à des rôles sensibles dans Azure AD et créer un incident haute sévérité.
EF-05	Visualisation de la posture des identités	Must Have	Fournir un Workbook interactif pour suivre les authentifications et la posture identité.
EF-06	Notification automatique des incidents critiques	Must Have	Déclencher une notification Teams lors d'un incident Sentinel de sévérité haute.
EF-07	Remédiation d'un compte compromis	Should Have	Permettre la révocation des sessions, la désactivation du compte et la traçabilité dans l'incident.

TABLE 2.2 – Synthèse des exigences fonctionnelles

2.2.2 Fiches détaillées des exigences

ID	Source / Acteurs	Description	Critères d'acceptation principaux
EF-01	US 1.1 — Epic 1 ; Administrateur sécurité	Le système doit disposer d'un espace de travail Log Analytics unique, déployé dans la région Azure appropriée et utilisé comme point central de collecte et stockage.	Workspace créé ; rétention configurée à 30 jours ; permissions RBAC restreintes ; journaux interrogeables par requêtes KQL basiques.
EF-02	US 1.2 — Epic 1 ; Administrateur sécurité, Analyste SOC	Microsoft Sentinel doit être activé sur le workspace Log Analytics et les connecteurs natifs Microsoft doivent ingérer les événements de sécurité.	Sentinel opérationnel ; connecteurs Azure AD, Azure Activity, Pare-feux Azure, VMs et Office 365 configurés ; logs visibles dans Log Analytics.
EF-03	US 2.1 — Epic 2 ; Analyste SOC	Le système doit détecter les connexions réussies provenant d'adresses IP malveillantes ou de pays inhabituels pour identifier les compromissions de comptes.	Requête KQL exploitant la Threat Intelligence ; exécution au moins horaire ; incident Sentinel généré ; entités Account et IP mappées.
EF-04	US 2.2 — Epic 2 ; Analyste SOC	Le système doit surveiller les logs d'audit Azure AD afin de détecter tout ajout à un rôle d'administrateur global ou sensible.	Requête KQL sur AuditLogs ; incident de sévérité Haute ; mapping Account/IP ; incident visible dans la file Sentinel.
EF-05	US 3.1 — Epic 3 ; Responsable sécurité, Analyste SOC	Le système doit fournir un Workbook interactif permettant d'évaluer rapidement la posture de sécurité des identités.	Graphique des connexions échouées par raison ; carte géographique ; filtres 24h et 7 jours ; accès depuis Sentinel sans droits d'administration.

ID	Source / Acteurs	Description	Critères d'acceptation principaux
EF-06	US 4.1 — Epic 4; Analyste SOC	Le système doit notifier automatiquement un canal Microsoft Teams dès la création d'un incident Sentinel de sévérité haute.	Logic App avec déclencheur Sentinel Incident ; extraction titre/sévérité/lien ; Adaptive Card Teams ; Automation Rule ; logs d'exécution.
EF-07	US 4.2 — Epic 4; Analyste SOC	Le système doit permettre le déclenchement manuel d'un Playbook de remédiation pour un compte Azure AD compromis.	Déclencheur Alert ou Incident ; Microsoft Graph ou connecteur Azure AD ; révocation sessions ; désactivation compte ; commentaire horodaté ; permission User.ReadWrite.All.

TABLE 2.3 – Fiches détaillées des exigences fonctionnelles

2.3 Spécifications non fonctionnelles

ID	Catégorie	Description	Critère de vérification
ENF-01	Performance	Les règles KQL doivent compenser le délai d'ingestion natif des logs Azure AD, pouvant atteindre 15 à 30 minutes, en utilisant <code>ingestion_time()</code> comme référence temporelle.	Aucune alerte ne doit être manquée à cause du décalage entre émission et ingestion.
ENF-02	Sécurité	Les permissions RBAC sur Log Analytics et les droits des identités managées Logic Apps doivent respecter le principe du moindre privilège.	Audit des permissions RBAC validé avant mise en service.
ENF-03	Fiabilité	Des Watchlists Sentinel doivent exclure les adresses IP et comptes de service légitimes afin de limiter les faux positifs et la saturation SOC.	Taux de faux positifs jugé acceptable lors des tests d'intégration.
ENF-04	Traçabilité	Toute action automatisée ou manuelle d'un Playbook SOAR doit être tracée par un commentaire horodaté dans l'incident Sentinel.	Chaque incident clôturé contient au moins un commentaire de traçabilité.

TABLE 2.4 – Exigences non fonctionnelles

2.4 Contraintes techniques

ID	Description
C-01	Le projet est intégralement réalisé dans un environnement de test Azure, de type sandbox. Toute action sur un environnement de production est exclue du périmètre.
C-02	Seuls les connecteurs de données natifs Microsoft sont utilisés. Le développement de connecteurs personnalisés via API REST est hors périmètre.
C-03	La durée d'exécution du projet est limitée à huit semaines, avec des jalons hebdomadaires alignés sur le planning prévisionnel.

TABLE 2.5 – Contraintes techniques du projet

2.5 Backlog produit

2.5.1 Epic 1 — Mise en place de l'infrastructure de base et collecte des logs

Objectif

Mettre en place le socle technique du SIEM Cloud-Native en créant le workspace Log Analytics, en activant Microsoft Sentinel et en connectant les sources de données natives Microsoft nécessaires à la centralisation des journaux.

ID	Ticket	Type	Priorité	Sprint	Statut
SIEM-1	Création de l'espace de travail Log Analytics	Story	High	Sprint 1 (S1-S2)	Terminé
SIEM-2	Activation d'Azure Sentinel et connexion des sources natives	Story	High	Sprint 1 (S1-S2)	Terminé

2.5.2 Epic 2 — Développement des capacités de détection (SIEM)

Objectif

Développer les capacités de détection du SIEM en configurant des règles analytiques KQL capables d'identifier les connexions suspectes, les sources malveillantes et les élévations de privilèges dans Azure AD.

ID	Ticket	Type	Priorité	Sprint	Statut
SIEM-3	Création de règles de détection pour les connexions suspectes	Story	High	Sprint 2 (S3-S4)	Terminé
SIEM-4	Création de règles de détection pour l'élévation de privilèges	Story	High	Sprint 2 (S3-S4)	Terminé

2.5.3 Epic 3 — Visualisation et Reporting (Workbooks)

Objectif

Concevoir des Workbooks interactifs permettant de visualiser la posture de sécurité, les indicateurs liés aux incidents, les tendances d'authentification et les informations utiles au responsable sécurité et à l'analyste SOC.

ID	Ticket	Type	Priorité	Sprint	Statut
SIEM-5	Création d'un tableau de bord de la posture d'identité	Story	Medium	Sprint 3 (S5-S6)	Terminé

2.5.4 Epic 4 — Automatisation de la réponse aux incidents (SOAR)

Objectif

Automatiser la réponse aux incidents récurrents à l'aide de Playbooks SOAR basés sur Azure Logic Apps, notamment la notification Teams et la remédiation par révocation de sessions ou désactivation de compte compromis.

ID	Ticket	Type	Priorité	Sprint	Statut
SIEM-6	Playbook de notification d'incident	Story	High	Sprint 3 (S5–S6)	Terminé
SIEM-7	Playbook de remédiation (Désactivation de compte)	Story	High	Sprint 4 (S7–S8)	

2.6 Analyse des risques et bugs anticipés

Le document de conception initiale identifie plusieurs risques techniques susceptibles d'affecter la fiabilité de la solution SIEM. Ces risques sont traités comme des bugs anticipés, car ils peuvent être prévenus par des choix de conception adaptés avant la phase de tests.

ID	Risque / bug anticipé	Impact potentiel	Mesure de prévention
B-01	Délai d'ingestion des logs Azure AD de 15 à 30 minutes.	Les règles KQL basées uniquement sur <code>TimeGenerated</code> peuvent manquer des événements dans la fenêtre de recherche.	Utiliser <code>ingestion_time()</code> dans les requêtes et ajuster la période de lookback.
B-02	Permission Microsoft Graph insuffisante pour la Managed Identity de la Logic App.	Le Playbook de désactivation de compte peut retourner une erreur <code>403 Forbidden</code> .	Accorder et documenter la permission <code>User.ReadWrite.All</code> avec validation du moindre privilège.
B-03	Faux positifs sur des IP ou comptes de service légitimes.	Saturation de la file d'incidents Sentinel et baisse d'efficacité de l'analyste SOC.	Mettre en place des Watchlists Sentinel pour exclure les IP et comptes approuvés.

TABLE 2.6 – Risques et bugs anticipés

Chapitre 3

Conception et choix technologiques

3.1 Vue d'ensemble de l'architecture cloud-native

L'architecture retenue est intégralement cloud-native et déployée sur Microsoft Azure. Elle ne repose sur aucune infrastructure on-premise et s'appuie exclusivement sur des services natifs Microsoft afin de simplifier l'intégration, la supervision et l'automatisation. Le système est conçu dans un environnement de test Azure, appelé sandbox, pour la durée du stage de deux mois.

La solution s'organise en quatre couches fonctionnelles séquentielles. La première couche collecte les journaux et métriques via Azure Monitor et les centralise dans un workspace Log Analytics. La deuxième couche active Microsoft Sentinel sur ce workspace afin d'analyser les événements, exécuter les règles KQL et créer des incidents. La troisième couche expose les données dans des Workbooks interactifs pour le suivi de la posture de sécurité. La quatrième couche automatise la réponse à l'aide de Playbooks SOAR construits avec Azure Logic Apps.

Couche	Composants principaux	Rôle fonctionnel
Collecte et ingestion	Azure Monitor, Log Analytics Workspace	Agréger les logs et métriques issus d'Azure AD, Azure Activity, Office 365, VMs et pare-feux Azure dans un point de centralisation unique.
Analyse et détection	Microsoft Sentinel, Analytics Rules KQL, Threat Intelligence, Watchlists	Corréler les événements, détecter les connexions suspectes et élévations de privilèges, réduire les faux positifs et générer des incidents.
Visualisation et reporting	Microsoft Sentinel Workbooks	Fournir des tableaux de bord interactifs : KPIs globaux, volume d'incidents, tendances, connexions échouées et carte géographique des origines.

Couche	Composants principaux	Rôle fonctionnel
Automatisation et remédiation	Azure Logic Apps, Automation Rules, Microsoft Teams, Microsoft Graph	Déclencher les Playbooks SOAR pour notifier l'équipe SOC, révoquer les sessions, désactiver un compte compromis et tracer les actions.

TABLE 3.1 – Vue d'ensemble de l'architecture SIEM Cloud-Native

Les flux suivent une chaîne opérationnelle continue : les sources Azure produisent des journaux, Azure Monitor les ingère dans Log Analytics, Sentinel exécute les règles de détection et crée les incidents, les Workbooks permettent l'analyse visuelle, puis Logic Apps prend en charge les actions de notification ou de remédiation selon la sévérité et le type d'incident.

3.2 Justification des choix technologiques

Le choix des composants techniques a reposé sur quatre critères principaux : l'intégration native avec l'environnement Azure, la capacité à couvrir les exigences SIEM/SOAR du projet, la simplicité de mise en œuvre dans un contexte de stage de deux mois, et la maîtrise des coûts dans un environnement de test. L'objectif n'était pas de multiplier les outils, mais de construire une chaîne cohérente allant de la collecte des journaux jusqu'à la réponse automatisée.

Couche	Solution retenue	Alternatives considérées	Justification principale
Collecte et stockage	Azure Monitor et Log Analytics Workspace	Elastic Agent, Splunk Forwarder, agents Syslog autonomes	Collecte native des journaux Azure, centralisation dans un workspace unique, requêtes KQL et configuration simple de la rétention.
Détection SIEM	Microsoft Sentinel	Splunk Enterprise Security, IBM QRadar, Elastic Security	Service cloud-native directement connecté à Log Analytics, règles analytiques KQL, gestion native des incidents et connecteurs Microsoft.
Visualisation	Microsoft Sentinel Workbooks	Grafana, Power BI, tableaux de bord personnalisés	Tableaux de bord intégrés à Sentinel, exploitation directe des requêtes KQL et absence d'infrastructure additionnelle.

Couche	Solution retenue	Alternatives considérées	Justification principale
Automatisation SOAR	Azure Logic Apps	Azure Functions, scripts PowerShell planifiés, solutions SOAR tierces	Déclenchement direct depuis les incidents Sentinel, connecteurs Teams/Email/Entra ID et modèle low-code adapté aux playbooks de réponse.
Identité et accès	Microsoft Entra ID et Azure RBAC	Comptes locaux, annuaires externes, droits manuels par ressource	Gestion centralisée des identités, traçabilité des opérations sensibles et contrôle d'accès cohérent sur les ressources Azure.

TABLE 3.2 – Synthèse des choix technologiques retenus

Couche collecte : Azure Monitor et Log Analytics

- **Solution retenue : Azure Monitor et Log Analytics Workspace.**
- **Rôle :** collecter, indexer et centraliser les journaux issus des ressources Azure, des machines virtuelles, d'Azure Activity, d'Entra ID et des services Microsoft connectés.
- **Justification :** l'intégration native avec Azure limite la configuration d'agents externes et permet d'interroger directement les données en **KQL**.
- **Alternative écartée :** une pile auto-hébergée de type Elastic ou une solution commerciale indépendante, plus lourde à administrer dans un environnement de test.

Couche détection : Microsoft Sentinel

- **Solution retenue : Microsoft Sentinel avec des Analytics Rules en KQL.**
- **Rôle :** analyser les journaux centralisés, corrélérer les événements, générer des alertes et créer des incidents exploitables par l'équipe sécurité.
- **Justification :** Sentinel s'active directement au-dessus de Log Analytics et couvre les cas d'usage du projet : connexions suspectes, pays inhabituels, IP malveillantes et élévations de privilèges.
- **Alternative écartée :** Splunk Enterprise Security, QRadar ou Elastic Security, plus coûteux ou plus complexes à intégrer dans le délai du stage.

Couche visualisation : Sentinel Workbooks

- **Solution retenue : Microsoft Sentinel Workbooks.**
- **Rôle :** transformer les requêtes KQL en tableaux, graphiques et indicateurs de supervision.
- **Justification :** les Workbooks sont directement intégrés à Sentinel et permettent de suivre les volumes d'événements, les incidents, les connexions suspectes et l'activité par utilisateur.
- **Alternative écartée :** Power BI ou Grafana, plus riches pour certains usages mais nécessitant une intégration supplémentaire.

Couche automatiser : Azure Logic Apps

- **Solution retenue : Azure Logic Apps** pour les **Playbooks SOAR.**
- **Rôle :** automatiser les actions de réponse aux incidents : notification Teams ou email, enrichissement, commentaires, révocation de sessions et désactivation de compte selon le scénario.
- **Justification :** Logic Apps fournit un modèle visuel, maintenable et directement connecté aux incidents Sentinel ainsi qu'aux services Microsoft.
- **Alternative écartée :** scripts isolés ou Azure Functions, moins lisibles pour un workflow SOAR et demandant davantage de maintenance technique.

Couche identité et accès : Entra ID et Azure RBAC

- **Solution retenue : Microsoft Entra ID et Azure RBAC.**
- **Rôle :** fournir les journaux d'authentification et d'audit, tout en contrôlant les permissions sur Log Analytics, Sentinel et les Playbooks.
- **Justification :** ce choix applique le principe du moindre privilège et rend les changements de privilèges exploitables comme cas d'usage de détection prioritaire.
- **Alternative écartée :** comptes locaux, annuaires externes ou droits manuels par ressource, moins cohérents et moins traçables dans Azure.

3.3 Modélisation UML du système

La modélisation UML permet de représenter les interactions fonctionnelles, les objets manipulés et les principaux flux d'exécution de la solution SIEM Cloud-Native. Les diagrammes suivants sont organisés par catégorie afin de distinguer les cas d'utilisation, le modèle de domaine, les scénarios dynamiques et l'architecture de composants.

3.3.1 Diagrammes de cas d'utilisation

Les diagrammes de cas d'utilisation présentent les interactions entre les acteurs du projet et les fonctionnalités principales regroupées par Epic.

UCd-01 — Epic 1 : Infrastructure et collecte

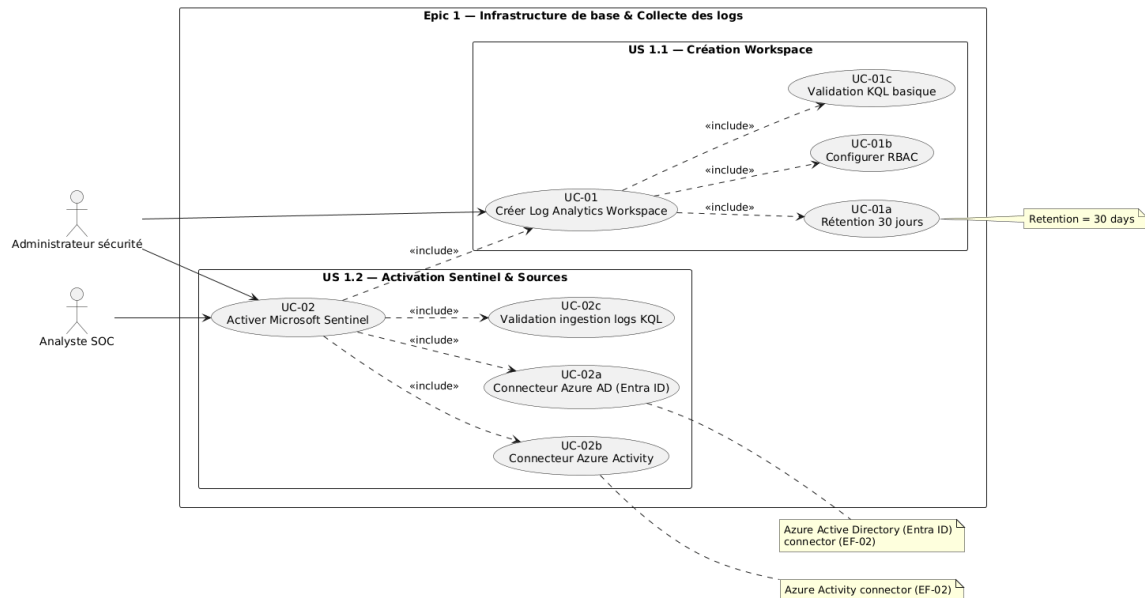


FIGURE 3.1 – UCd-01 — Cas d'utilisation de l'Epic 1 : Infrastructure et collecte

UCd-02 — Epic 2 : Détection SIEM

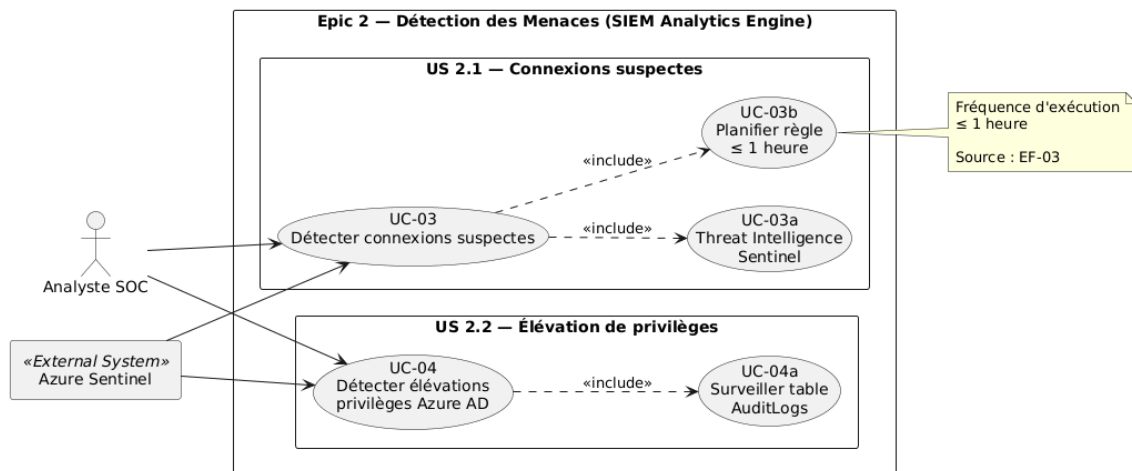


FIGURE 3.2 – UCd-02 — Cas d'utilisation de l'Epic 2 : Détection SIEM

UCd-03 — Epic 3 : Visualisation Workbooks

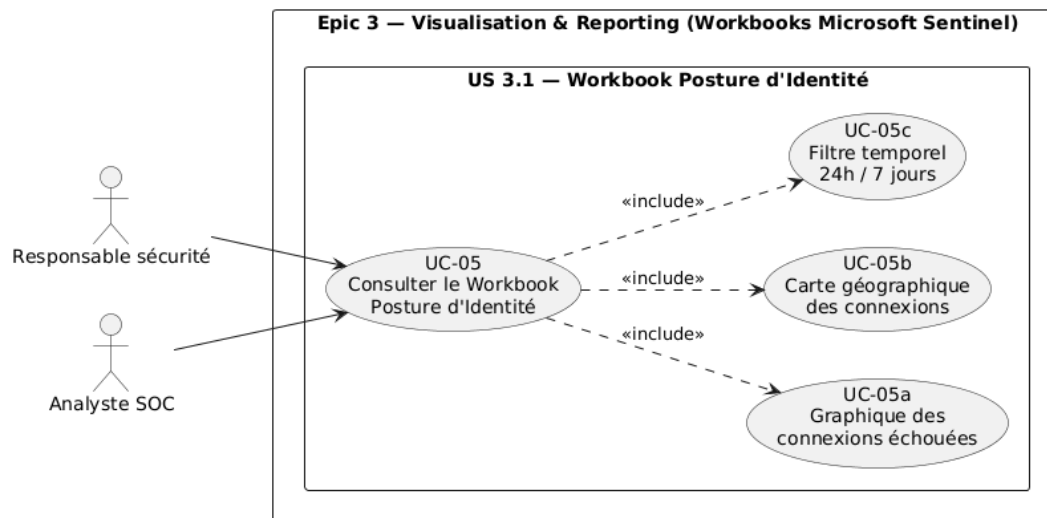


FIGURE 3.3 – UCd-03 — Cas d'utilisation de l'Epic 3 : Visualisation avec Workbooks

UCd-04 — Epic 4 : Automatisation SOAR

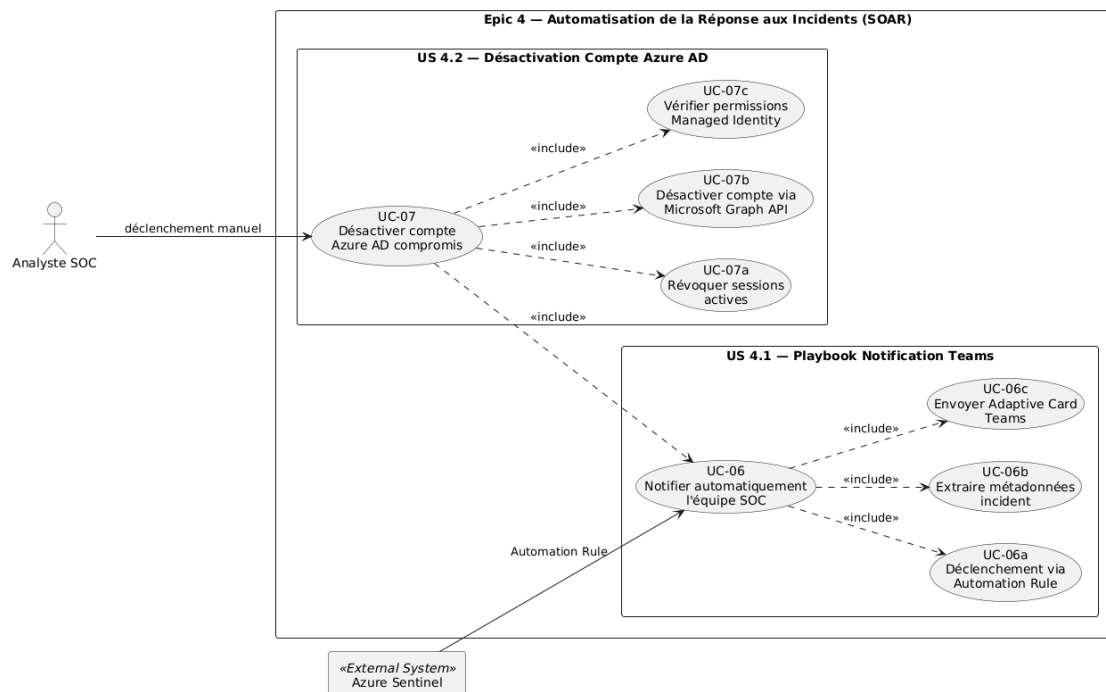


FIGURE 3.4 – UCd-04 — Cas d'utilisation de l'Epic 4 : Automatisation SOAR

3.3.2 Diagrammes de classes et modèle de domaine

Les diagrammes de classes structurent les principaux objets techniques du système : ressources d'infrastructure, règles de détection, tableaux de bord et automatisations SOAR.

CLD-01 — Modèle de domaine : Couche infrastructure

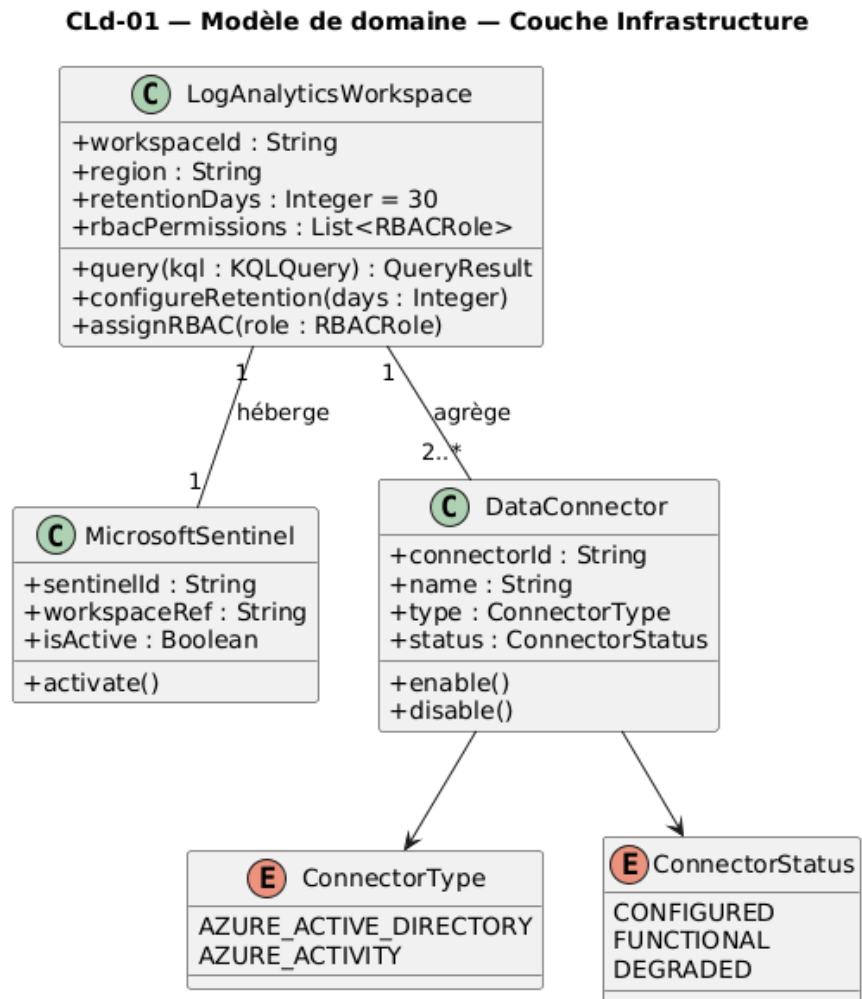


FIGURE 3.5 – CLD-01 — Modèle de domaine de la couche infrastructure

CLD-02 — Modèle de domaine : Couche détection

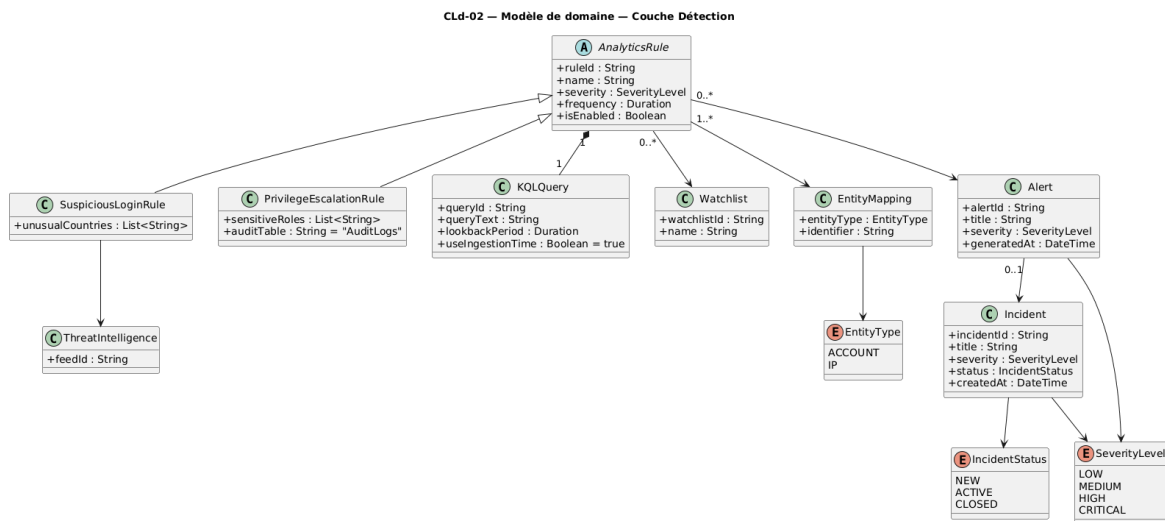


FIGURE 3.6 – CLD-02 — Modèle de domaine de la couche détection

CLD-03 — Modèle de domaine : Couche visualisation

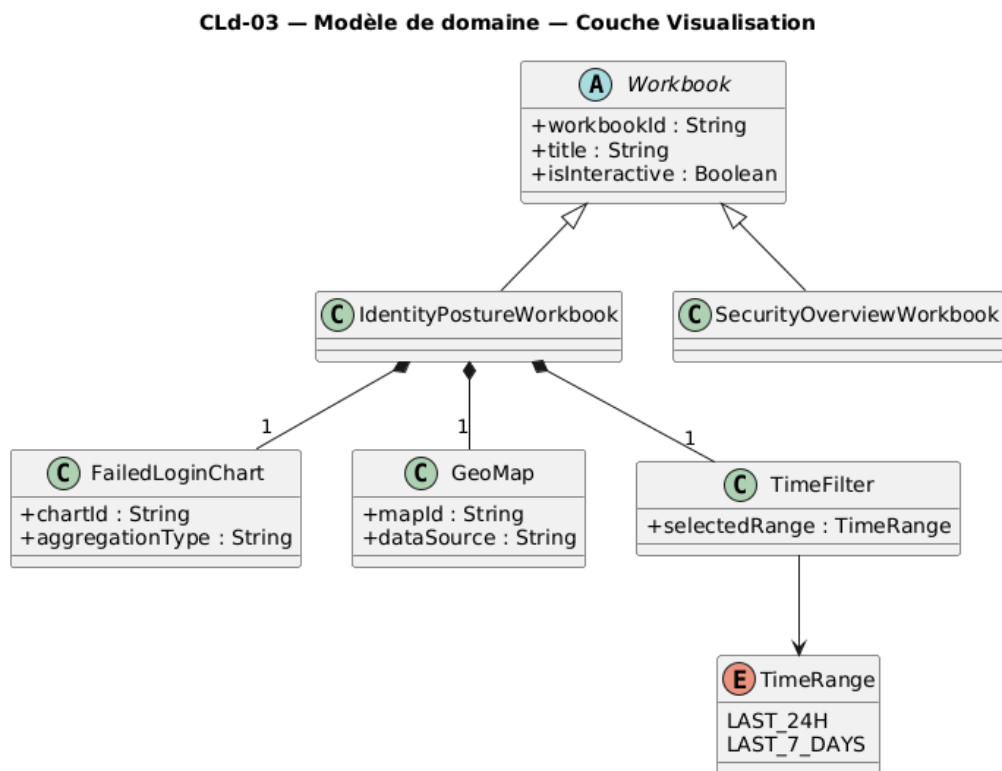


FIGURE 3.7 – CLD-03 — Modèle de domaine de la couche visualisation

CLD-04 — Modèle de domaine : Couche automatisation SOAR

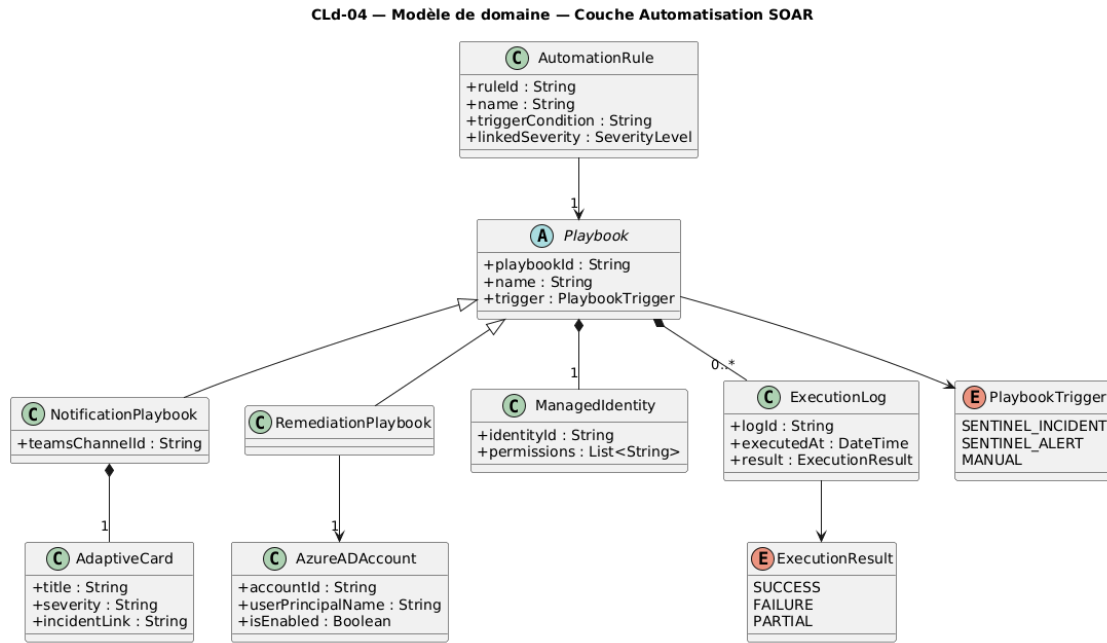


FIGURE 3.8 – CLD-04 — Modèle de domaine de la couche automatisation SOAR

3.3.3 Diagrammes de séquence

Les diagrammes de séquence décrivent le comportement dynamique du système lors des scénarios majeurs : détection d'une menace, génération d'incident, notification et remédiation.

SEQ-01 — Détection d'une connexion suspecte par IP malveillante

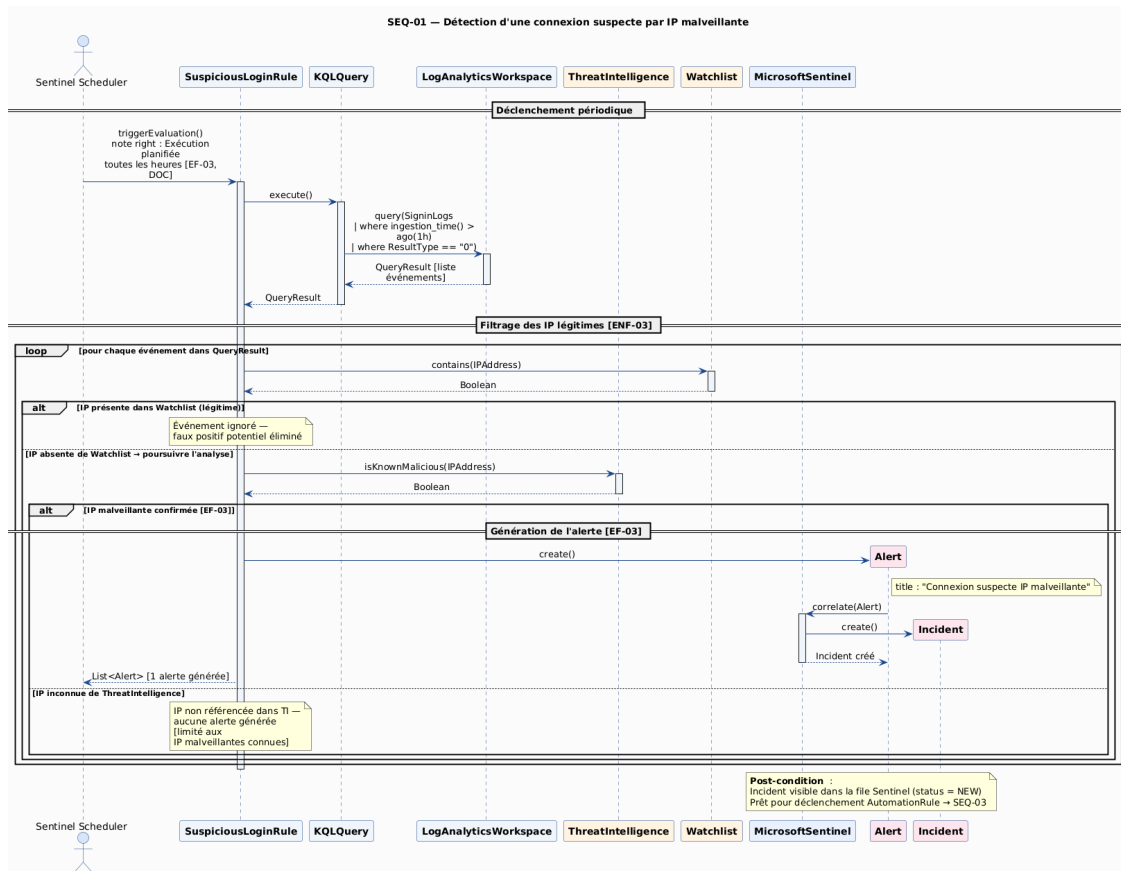


FIGURE 3.9 — SEQ-01 — Séquence de détection d'une connexion suspecte par IP malveillante

SEQ-02 — Détection d'une élévation de privilèges

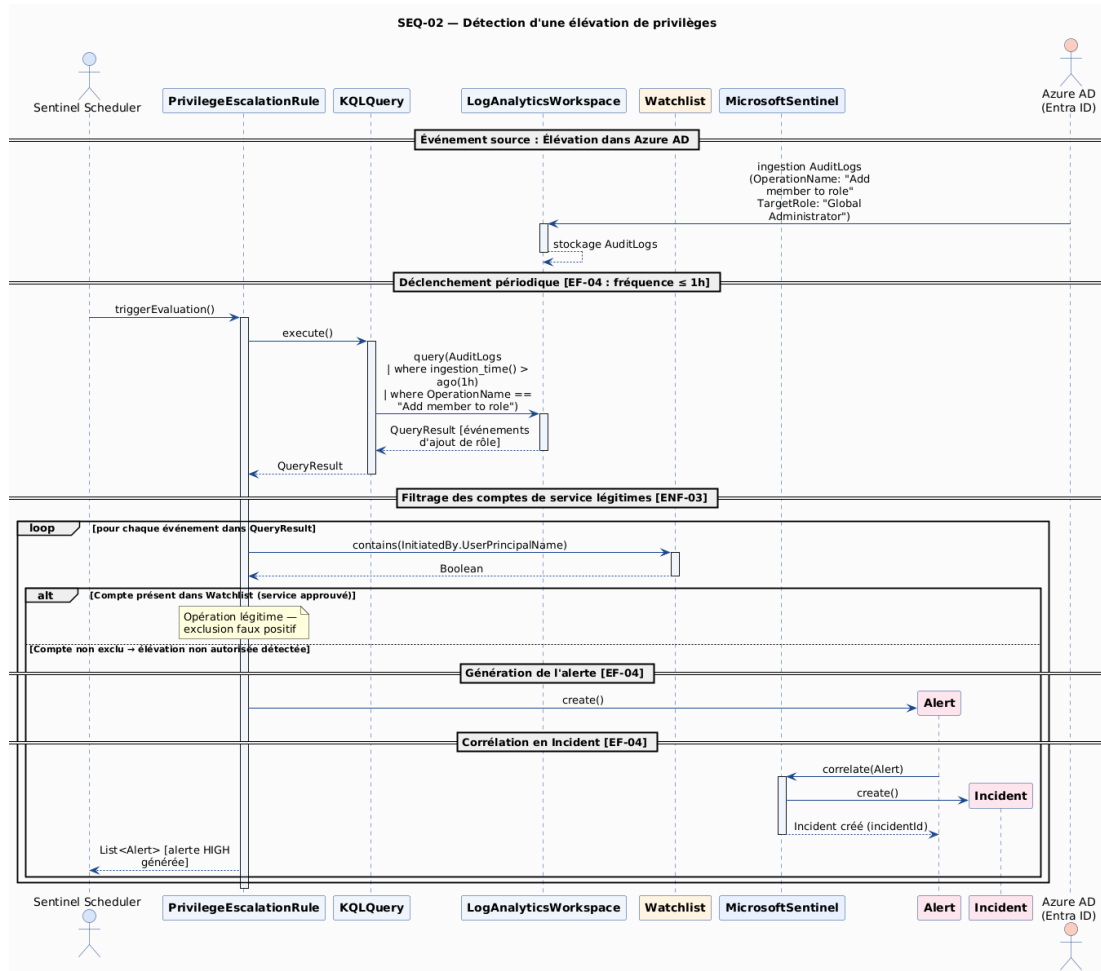


FIGURE 3.10 – SEQ-02 — Séquence de détection d'une élévation de privilèges

SEQ-03 — Notification automatique Teams

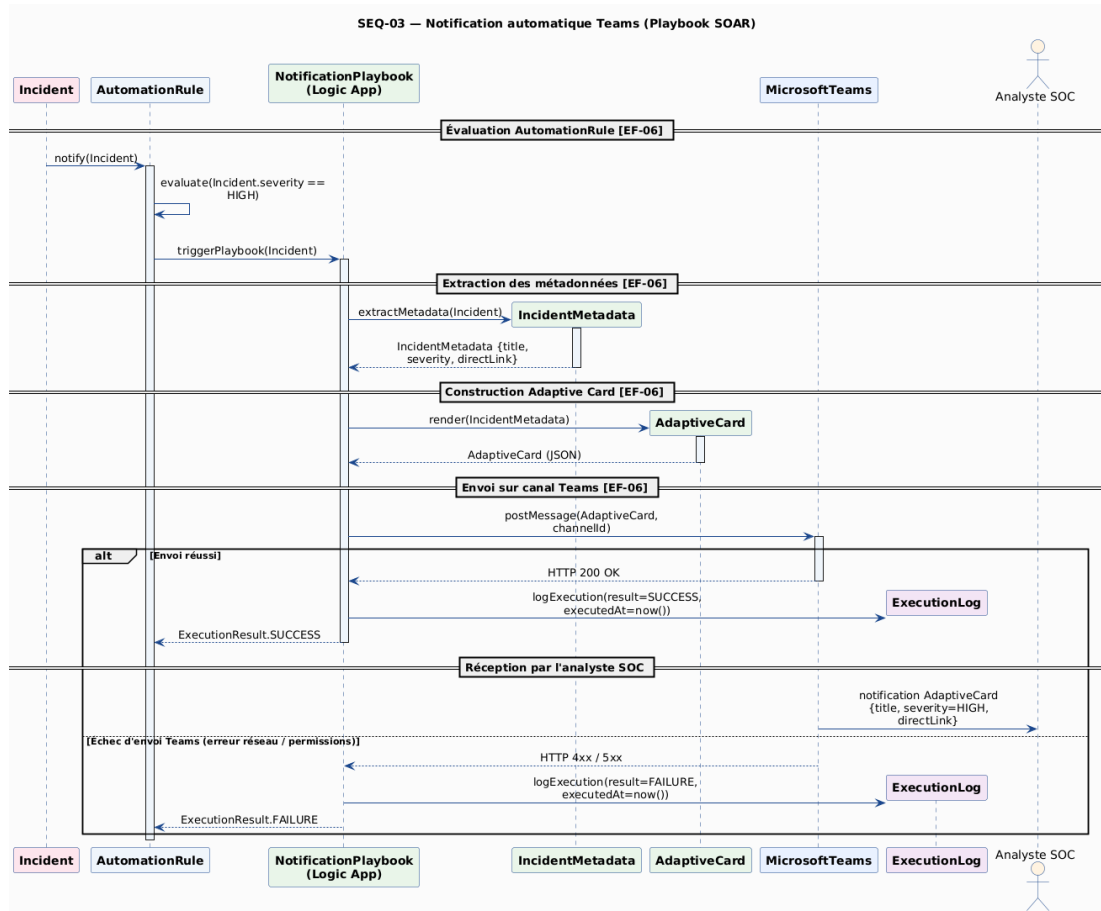


FIGURE 3.11 – SEQ-03 — Séquence de notification automatique Teams par Playbook SOAR

SEQ-04 — Remédiation par désactivation de compte compromis

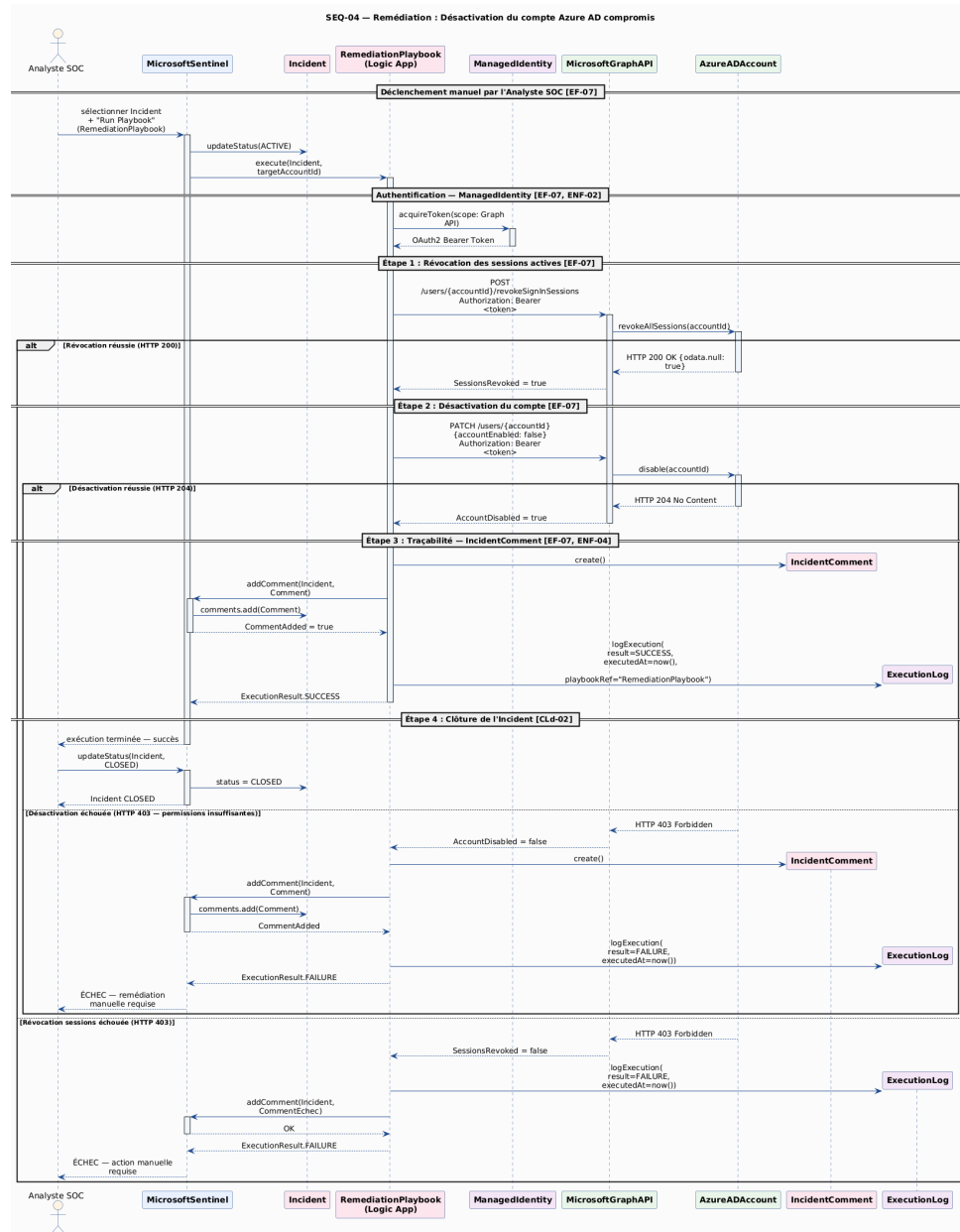


FIGURE 3.12 — SEQ-04 — Séquence de remédiation par désactivation de compte compromis

3.3.4 Architecture C4 et diagramme de composants

Le diagramme de composants présente une vue C4 Container de la solution. Il met en évidence les sources de journaux, le workspace Log Analytics, Microsoft Sentinel, les Workbooks et les Playbooks Logic Apps.

IO-02 — Diagramme de composants / Architecture C4 Container

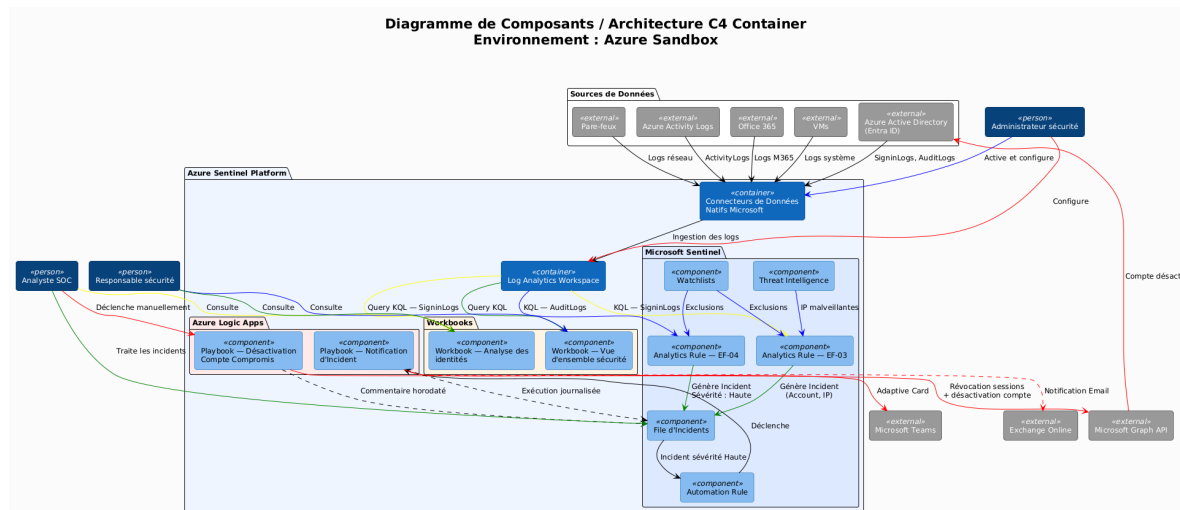


FIGURE 3.13 – IO-02 — Diagramme de composants et architecture C4 Container du SIEM Cloud-Native

3.4 Estimation des coûts des ressources Azure

3.4.1 Hypothèses et paramètres d'estimation

L'estimation budgétaire porte sur un environnement de test utilisé pendant la durée du stage. Elle vise à donner un ordre de grandeur des ressources Azure nécessaires au prototype SIEM Cloud-Native, sans inclure les coûts d'une exploitation de production à grande échelle.

Paramètre	Valeur retenue
Région Azure	France Central
Durée du projet	2 mois
Volume moyen de logs ingérés	2 Go par jour
Rétention des journaux	30 jours
Machines virtuelles supervisées	2 VMs de test
Nombre de Playbooks SOAR	2 Playbooks Logic Apps
Usage des Workbooks	Inclus dans Microsoft Sentinel
Objectif de l'estimation	Prototype et environnement sandbox

TABLE 3.3 – Hypothèses retenues pour l'estimation des coûts Azure

Les montants présentés ci-dessous sont donc indicatifs. Ils permettent surtout d'évaluer la soutenabilité du prototype et d'identifier les postes de coût dominants : ingestion de données, analyse Sentinel, machines virtuelles de test et automatisations Logic Apps.

3.4.2 Détail des coûts par service

Service Azure	Base d'estimation	Coût mensuel estimé	Commentaire
Log Analytics	Ingestion de 2 Go/jour, soit environ 60 Go/mois	150 USD	Stockage et interrogation centralisés des journaux.
Microsoft Sentinel	Analyse SIEM sur le même volume de 60 Go/mois	120 USD	Corrélation, règles analytiques, alertes et incidents.
Machines virtuelles de test	2 VMs supervisées pendant un mois	80 USD	Environnement de simulation et génération d'événements.
Azure Logic Apps	2 Playbooks avec exécutions limitées	20 USD	Automatisation SOAR et notifications.

Service Azure	Base d'estimation	Coût mensuel estimé	Commentaire
Stockage et trafic divers	Stockage auxiliaire, métriques et opérations mineures	30 USD	Marge pour ressources associées et variations d'usage.
Total mensuel estimé	Environnement sandbox	400 USD	Ordre de grandeur mensuel.

TABLE 3.4 – Estimation des coûts mensuels des ressources Azure

Sur la durée totale du stage, soit deux mois, le coût global estimé est donc d'environ **800 USD**. Cette estimation reste cohérente avec un prototype de SIEM cloud-native à faible volumétrie. En production, les coûts augmenteraient principalement avec le volume de journaux ingérés, la durée de rétention, le nombre de sources connectées et la fréquence d'exécution des Playbooks.

Le principal levier d'optimisation consiste à filtrer les sources de données non pertinentes, ajuster la rétention selon les exigences de conformité et surveiller régulièrement l'usage du workspace Log Analytics. Cette approche permet de conserver une couverture de supervision suffisante tout en limitant les dépenses inutiles.

Chapitre 4

Conformité, sécurité et évaluation

4.1 Présentation de la norme ISO/IEC 27001 :2022

ISO/IEC 27001 :2022 est la norme internationale de référence pour les **Systèmes de Management de la Sécurité de l'Information** (SMSI). Dans sa troisième édition, publiée en octobre 2022, elle définit un cadre structuré permettant aux organisations d'établir, mettre en œuvre, maintenir et améliorer leur posture de sécurité de manière continue.

La norme s'articule autour de dix clauses principales. Les clauses 4 à 10 constituent le corps normatif obligatoire : contexte de l'organisation, leadership, planification, support, fonctionnement, évaluation des performances et amélioration. Ces clauses imposent une **approche de gestion basée sur le risque**, dans laquelle l'organisation identifie ses actifs informationnels, évalue les menaces et vulnérabilités associées, puis sélectionne les contrôles adaptés pour réduire les risques à un niveau acceptable.

L'Annexe A de la norme liste **93 contrôles** regroupés en quatre domaines : contrôles organisationnels, contrôles liés aux personnes, contrôles physiques et contrôles technologiques. L'édition 2022 introduit notamment le contrôle **5.23**, consacré à la sécurité de l'information pour l'utilisation de services en nuage, ce qui rend la norme particulièrement pertinente pour un projet SIEM cloud-native.

La logique centrale de la norme repose sur la triade **Confidentialité, Intégrité et Disponibilité** (CIA). Dans cette perspective, un projet SIEM ne se limite pas à un ensemble d'outils techniques : il contribue également à la surveillance, à la traçabilité, à la réponse aux incidents et à l'amélioration continue de la sécurité.

4.2 Contrôles ISO pertinents pour le projet SIEM Cloud-Native avec Azure Monitor & Sentinel

Le projet SIEM de SMARTOVATE LTD vise à déployer une infrastructure de supervision de sécurité centralisée sur Azure, intégrant **Azure Monitor**, **Log Analytics**, **Microsoft Sentinel** et des **Playbooks SOAR** via **Azure Logic Apps**. L'analyse ci-dessous identifie les contrôles ISO/IEC 27001 :2022 directement adressés par ce projet.

Contrôle 8.15 — Enregistrement (Logging)

- C'est le contrôle le plus directement couvert. La norme exige que les journaux enregistrant les activités, exceptions, défaillances et événements pertinents soient produits, stockés, protégés et analysés. Le projet répond à cette exigence par la création d'un espace de travail **Log Analytics** centralisé, avec une rétention configurée à 30 jours, et l'ingestion de journaux provenant d'**Azure AD**, **Azure Activity**, **Office 365** et des machines virtuelles. L'alignement est fort et documenté.

Contrôle 8.16 — Activités de suivi (Monitoring)

- La norme requiert la surveillance des réseaux, systèmes et applications pour détecter tout comportement anormal. **Microsoft Sentinel** constitue le moteur central de détection : les règles d'analyse **KQL** personnalisées identifient les connexions suspectes depuis des IP malveillantes, les connexions depuis des pays inhabituels et les élévations de privilèges sur **Azure AD**. Les **Workbooks** fournissent une visualisation continue de la posture de sécurité. Cet alignement est direct et exhaustif.

Contrôle 5.25 — Évaluation des événements de sécurité et 5.26 — Réponse aux incidents

- La norme impose d'évaluer les événements de sécurité et d'y répondre selon des procédures documentées. Le projet implémente ce processus : **Microsoft Sentinel** génère des incidents à partir des alertes déclenchées, tandis que les **Playbooks SOAR** automatisent la réponse, notamment la notification Teams/Email et la désactivation de compte **Azure AD**. La traçabilité est assurée par les commentaires ajoutés automatiquement aux incidents **Sentinel**. L'alignement est complet sur le plan technique ; la documentation des procédures reste à formaliser.

Contrôle 5.24 — Planification et préparation de la gestion des incidents

- La norme exige la définition préalable des processus, rôles et responsabilités pour la gestion des incidents. Le projet définit des critères d'acceptation clairs pour chaque User Story, notamment les sévérités d'incidents, les règles d'automatisation liant les Playbooks aux niveaux de sévérité et les canaux de notification. La mise en place d'une **Automation Rule** constitue une implémentation technique de ce contrôle.

Contrôle 5.7 — Renseignements sur les menaces (Threat Intelligence)

- La norme demande la collecte et l'analyse d'informations sur les menaces afin de produire des renseignements exploitables. Le projet intègre la **Threat Intelligence** dans ses requêtes **KQL** pour la détection de connexions depuis des IP malveillantes connues. Cette capacité renforce la pertinence des règles de détection et contribue à réduire le temps moyen de détection.

Contrôle 5.15 & 5.16 — Contrôle d'accès et gestion de l'identité

- La norme impose la gestion complète du cycle de vie des identités et l'application de règles de contrôle d'accès. Le projet surveille en temps réel les modifications de rôles sensibles dans **Azure**

AD, notamment l'ajout au rôle Administrateur Global, et automatise la révocation de sessions ainsi que la désactivation de comptes compromis. Les permissions **RBAC** du workspace Log Analytics restreignent l'accès à l'équipe de sécurité. L'alignement est fort sur la réponse aux incidents d'identité.

Contrôle 8.2 — Droits d'accès privilégiés

- La norme exige de restreindre et gérer l'attribution des droits d'accès privilégiés. Le projet intègre une règle de détection dédiée à l'élévation de privilèges, qui surveille les logs d'audit Azure AD et génère un incident de sévérité haute lors de l'ajout à des rôles d'administrateur. C'est un alignement direct et proactif.

Contrôle 5.23 — Sécurité de l'information pour l'utilisation de services en nuage

- Ce contrôle, introduit dans l'édition 2022, demande d'établir des processus pour l'acquisition, l'utilisation, la gestion et la sortie des services cloud. Le projet opère entièrement sur Azure et utilise des services natifs Microsoft : Sentinel, Log Analytics, Logic Apps et Entra ID. La gouvernance des services cloud est donc inhérente à l'architecture. Toutefois, la norme attend une documentation formelle des politiques d'utilisation cloud, à produire en complément du guide technique.

Contrôle 9.1 — Suivi, mesure, analyse et évaluation

- La norme impose de définir ce qui doit être surveillé, avec des méthodes produisant des résultats reproductibles. Les Workbooks du projet, notamment la vue d'ensemble sécurité et l'analyse des identités, fournissent des métriques visualisables et filtrables. Les règles KQL planifiées assurent la reproductibilité des mesures. L'alignement est satisfaisant.

Contrôle 5.28 — Collecte des preuves

- La norme requiert des procédures pour l'identification, la collecte et la conservation des preuves relatives aux événements de sécurité. Log Analytics stocke les événements bruts. Les Playbooks ajoutent des commentaires structurés dans les incidents Sentinel, constituant une traçabilité des actions de remédiation. La durée de rétention de 30 jours, adaptée à l'environnement de test, devra être alignée sur les exigences légales en production.

Contrôle 8.6 — Gestion des capacités

- Azure Monitor collecte en continu les métriques de performance telles que CPU, mémoire et latence réseau des ressources Azure. Cette supervision permet d'anticiper les saturations et d'ajuster les capacités selon les besoins. Le contrôle 8.6 est ainsi couvert en complément du rôle de collecte de logs qu'Azure Monitor partage avec le contrôle 8.15.

4.3 Cartographie ISO 27001 et architecture

La cartographie ci-dessous représente la correspondance entre les composants techniques du projet et les contrôles ISO/IEC 27001 :2022.

Composant Azure	Contrôle ISO	Description de l'alignement
Log Analytics Workspace	8.15 — Enregistrement	Centralise la collecte, le stockage et la protection des journaux provenant d' Azure AD , Azure Activity , Office 365 et VMs . Rétention configurable alignée sur les exigences de conservation.
Sentinel — Règles KQL	8.16 — Surveillance	Les Analytics Rules détectent les comportements anormaux (connexions suspectes, IP malveillantes).
	5.7 — Threat Intelligence	L'intégration de la Threat Intelligence étend la détection au-delà des anomalies comportementales. Les Watchlists filtrent les faux positifs .
Sentinel — Gestion des incidents	5.24 — Planification incidents	Structure les incidents Sentinel selon un processus préparé de classification et de traitement.
	5.25 — Évaluation événements	Corrèle les alertes en incidents avec mapping d'entités (Account , IP) et sévérité assignée (Haute, Moyenne).
	5.26 — Réponse incidents	Fournit l'implémentation technique du processus de réponse aux événements de sécurité .

TABLE 4.1 – Cartographie des composants SIEM et contrôles ISO/IEC 27001 :2022

Composant Azure	Contrôle ISO	Description de l'alignement
Logic Apps — Playbooks SOAR	5.26 — Réponse incidents	Playbook 1 : notification automatique sur Teams pour réduire le MTTD et accélérer la prise en charge.
	5.16 — Gestion des identités	Playbook 2 : désactivation du compte compromis via Microsoft Graph , avec traçabilité dans l' incident Sentinel .
Workbooks	9.1 — Suivi et mesure	Tableaux de bord interactifs : carte géographique, statistiques d' authentification et filtres temporels .
	5.35 — Revue indépendante	Support des revues périodiques de la posture de sécurité communicables à la direction.
RBAC sur Log Analytics	5.15 — Contrôle d'accès	Restreint l'accès au workspace Log Analytics à l' équipe SOC autorisée.
	5.18 — Droits d'accès	Applique le principe de moindre privilège sur les données de journalisation dès la création du workspace.
Règle détection privilèges	8.2 — Accès privilégiés	Surveille les logs d'audit Azure AD pour tout ajout à un rôle Administrateur Global .
	5.16 — Gestion des identités	Génère un incident de sévérité Haute avec mapping Account/IP pour l'identité concernée.
Architecture cloud native	5.23 — Services en nuage	Utilisation exclusive de services natifs Azure (Sentinel, Log Analytics, Logic Apps, Entra ID). Gouvernance cloud inhérente à l'architecture. Politique d'utilisation cloud formelle à documenter.
Environnement sandbox	8.31 — Séparation des environnements	Le projet opère dans un environnement de test isolé de la production . La séparation est effective mais non formellement documentée dans les livrables prévus.
Azure Monitor	8.15 — Enregistrement	Collecte et agrège les métriques et logs de l'ensemble de l' infrastructure Azure (VMs, pare-feux, services).
	8.16 — Surveillance	Constitue la couche d'observabilité primaire avant transmission à Log Analytics .
	8.6 — Gestion des capacités	Suit les métriques de performance et la disponibilité des ressources surveillées .

TABLE 4.2 – Cartographie des composants SIEM et contrôles ISO/IEC 27001 :2022 (suite)

4.4 Bilan de conformité et recommandations d'amélioration

L'analyse montre que l'architecture SIEM Cloud-Native proposée présente un **niveau d'alignement fort** avec plusieurs contrôles ISO/IEC 27001 :2022, en particulier ceux relatifs à la journalisation, à la surveillance, à la réponse aux incidents, à la gestion des identités et à la mesure de la posture de sécurité. Les composants Azure sélectionnés couvrent les besoins techniques essentiels d'un dispositif de supervision sécurité moderne.

Les principaux points forts sont la centralisation des journaux dans Log Analytics, la détection par règles KQL dans Sentinel, l'automatisation SOAR par Logic Apps, la visualisation par Workbooks et la prise en compte des identités via Azure AD/Entra ID et RBAC.

Cependant, certains éléments doivent être renforcés avant un déploiement en production :

- formaliser les procédures de gestion des incidents et les responsabilités associées ;
- documenter une politique d'utilisation des services cloud conforme au contrôle 5.23 ;
- adapter la durée de rétention des journaux aux exigences légales, contractuelles et métier ;
- formaliser la séparation entre environnement de test et environnement de production ;
- enrichir progressivement les scénarios de détection et les indicateurs de pilotage.

En conclusion, la solution conçue dans le cadre du stage constitue une base cohérente et conforme aux principes de l'ISO/IEC 27001 :2022. Elle permet de démontrer la faisabilité technique d'une supervision SIEM cloud-native tout en identifiant les compléments documentaires et organisationnels nécessaires pour atteindre un niveau de conformité plus complet en production.

Conclusion générale et perspectives

Le stage de deux mois réalisé au sein de **SMARTOVATE LTD** avait pour objectif la conception et le déploiement d'une solution **SIEM Cloud-Native** reposant sur Azure Monitor et Microsoft Sentinel, dans un environnement de test sandbox. Cette conclusion revient sur les objectifs atteints, l'apport personnel du stage, les compétences acquises, les limites du travail réalisé et les perspectives d'évolution de la solution.

Bilan des objectifs atteints

Les cinq objectifs fixés en début de stage (**OBJ-01 à OBJ-05**) ont été traités selon des niveaux d'aboutissement variables, documentés tout au long du rapport. Le workspace Log Analytics a été déployé et configuré avec une rétention de 30 jours et des permissions RBAC restreintes (**OBJ-01**). Microsoft Sentinel a été activé sur ce workspace, avec une connexion effective au connecteur Azure Activity ; les connecteurs Azure AD (**SigninLogs, AuditLogs**) se sont en revanche heurtés à une limitation liée aux Diagnostic Settings dans l'environnement sandbox, documentée aux tickets **SIEM-6** et **SIEM-7 (OBJ-02)**. Cette contrainte a conduit à une adaptation méthodologique : les règles de détection initialement conçues pour s'appuyer sur SigninLogs et AuditLogs ont été réécrites autour de la table AzureActivity, retenue comme source de substitution, tout en conservant l'objectif fonctionnel visé — détection des opérations sensibles et des élévations de privilèges RBAC (**OBJ-03**). Deux Workbooks ont été conçus, exploitant les requêtes KQL développées pour restituer les KPIs, les tendances temporelles et la posture de sécurité (**OBJ-04**). Enfin, les Playbooks SOAR de notification et de remédiation ont été développés avec Azure Logic Apps, incluant la révocation de sessions, la désactivation de compte et la traçabilité par commentaires horodatés dans les incidents Sentinel (**OBJ-05**). Ce bilan illustre une caractéristique essentielle du travail réalisé : la capacité à diagnostiquer un blocage technique, à en documenter la cause, et à proposer une solution de contournement fonctionnellement équivalente sans dénaturer l'objectif métier initial.

Limites du travail réalisé

Plusieurs limites doivent être soulignées avec honnêteté. La principale contrainte technique a été l'indisponibilité des tables SigninLogs et AuditLogs dans l'environnement sandbox, qui a empêché la mise en œuvre des règles de détection dans leur conception d'origine et a nécessité un repli sur AzureActivity comme source de données. Si cette adaptation reste techniquement défendable, elle ne permet pas de valider la solution sur les cas d'usage réels de détection d'authentification (connexions suspectes par IP, pays inhabituels) tels qu'initialement spécifiés dans les exigences **EF-03** et **EF-05**.

Par ailleurs, la solution a été développée et testée exclusivement dans un environnement de test à faible volumétrie, ce qui limite la portée des enseignements en matière de performance, de coût réel et de gestion des faux positifs à grande échelle. Enfin, comme relevé dans le bilan de conformité, plusieurs éléments organisationnels — formalisation des procédures de gestion des incidents, politique documentée d'utilisation des services cloud, séparation formelle test/production — restent à produire pour atteindre un niveau de conformité ISO/IEC 27001 :2022 complet.

Perspectives d'évolution

Plusieurs axes d'amélioration se dégagent naturellement de ce travail. À court terme, la résolution de l'obstacle lié aux Diagnostic Settings permettrait de réactiver les connecteurs SigninLogs et Audit-Logs et de valider les règles de détection dans leur conception originale. L'enrichissement du nombre de règles analytiques et de Playbooks, au-delà du périmètre minimal fixé (5 à 10 règles, 2 Workbooks, 2 Playbooks), renforcerait la couverture de détection. À moyen terme, un déploiement en environnement de pré-production permettrait de mesurer la solution sur un volume de journaux réaliste et d'ajuster les seuils de détection afin de limiter les faux positifs à l'aide des Watchlists Sentinel. Enfin, la formalisation des recommandations issues du bilan de conformité — documentation des procédures de gestion des incidents, politique d'utilisation cloud, adaptation de la durée de rétention aux exigences légales — constituerait une étape nécessaire avant tout passage en production, transformant ce prototype fonctionnel en une solution SIEM Cloud-Native pleinement opérationnelle et conforme.

Bibliographie

- [1] Companies House (GOV.UK). *SMARTOVATE LTD – Company number 15865802, Officers*. <https://find-and-update.company-information.service.gov.uk/company/15865802/officers>
- [2] StationX. *Cloud Security Statistics [2026] : Key Data & Trends*. StationX, 2026. <https://app.stationx.net/articles/cloud-security-statistics>
- [3] DataStackHub. *50 Cloud Data Security Statistics For 2025–2026*. DataStackHub, 2025. <https://www.datastackhub.com/insights/cloud-data-security-statistics/>
- [4] DataStackHub. *Cloud Threat Statistics For 2025–2026*. DataStackHub, 2025. <https://www.datastackhub.com/insights/cloud-threat-statistics/>
- [5] DataStackHub. *50 Cloud Security Statistics For 2025–2026*. DataStackHub, 2026. <https://www.datastackhub.com/insights/cloud-security-statistics/>
- [6] Rose, S. *NIST Special Publication 800-207 : Zero Trust Architecture*. National Institute of Standards and Technology, 2020. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>
- [7] NIST. *SP 800-207, Zero Trust Architecture – résumé officiel*. National Institute of Standards and Technology. <https://csrc.nist.gov/pubs/sp/800/207/final>
- [8] Schwaber, K. et Sutherland, J. *The Scrum Guide – The Definitive Guide to Scrum : The Rules of the Game*. Scrum.org & Scrum Inc., novembre 2020. <https://scrumguides.org/>
- [9] International Organization for Standardization / International Electrotechnical Commission. *ISO/IEC 27001 :2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*. Genève : ISO/IEC, 2022.
- [10] Microsoft. *What is Microsoft Sentinel SIEM ?*. Microsoft Learn, 2026. <https://learn.microsoft.com/en-us/azure/sentinel/overview>
- [11] Cloud Direct. *Microsoft Sentinel vs. Traditional SIEMs*. Cloud Direct, 2026. <https://clouddirect.net/learning-hub/microsoft-sentinel-vs-traditional-siems/>

Annexe A

Requêtes KQL intégrales

A.1 SIEM-3 — Création de l'espace de travail Log Analytics

KQL-3.1 — Test de connectivité du workspace

```
1 search *  
2 | take 5
```

Requête minimale de validation : vérifie que le workspace Log Analytics est opérationnel et accepte des requêtes. Retourne 0 résultats si aucune donnée n'est encore ingérée, ce qui est normal à ce stade — l'absence d'erreur suffit à confirmer le bon fonctionnement.

A.2 SIEM-4 — Activation de Sentinel et connexion des sources natives

KQL-4.1 — Validation SigninLogs (Azure AD)

```
1 SigninLogs  
2 | project TimeGenerated, UserPrincipalName, ResultType, Location, AppDisplayName  
3 | order by TimeGenerated desc  
4 | take 10
```

Vérifie que le connecteur Azure Active Directory est actif et alimente la table **SigninLogs**. Le champ **ResultType == "0"** indique une connexion réussie et constitue la base des règles de détection de SIEM-6. Non disponible dans l'environnement actuel en raison de la saturation des Diagnostic Settings.

KQL-4.2 — Validation AuditLogs (Azure AD)

```
1 AuditLogs  
2 | project TimeGenerated, OperationName, Result, InitiatedBy
```

```

3 | order by TimeGenerated desc
4 | take 10

```

Vérifie l'alimentation de la table `AuditLogs` par le connecteur Azure AD. Source principale pour la détection d'élévation de privilèges (SIEM-7) — **non disponible dans l'environnement actuel** en raison de l'obstacle Diagnostic Settings documenté dans les tickets SIEM-6 et SIEM-7.

KQL-4.3 — Validation AzureActivity

```

1 AzureActivity
2 | project TimeGenerated, OperationNameValue, ActivityStatusValue, Caller
3 | order by TimeGenerated desc
4 | take 10

```

Vérifie que le connecteur Azure Activity envoie bien des logs vers le workspace. Cette table constitue la **source de substitution** utilisée pour toutes les règles de détection adaptées (SIEM-6, SIEM-7) en remplacement des tables `SigninLogs` et `AuditLogs` non disponibles.

KQL-4.4 — Vue globale des tables actives

```

1 union withsource=_TableName *
2 | where TimeGenerated > ago(1h)
3 | summarize NombreLogs=count() by _TableName
4 | where _TableName in ("AzureActivity", "SigninLogs", "AuditLogs")
5 | order by NombreLogs desc

```

Diagnostic rapide multi-tables : confirme en une seule requête quelles sources de données sont actives. **Adaptation syntaxique** : utilise `_TableName` (avec underscore) au lieu de `TableName` pour éviter le conflit de colonne natif ayant généré l'erreur "column named 'TableName' already exists" lors des premiers tests.

A.3 SIEM-5 / SIEM-6 — Détection des connexions suspectes

KQL-6.1 — Diagnostic des opérations disponibles

```

1 AzureActivity
2 | where TimeGenerated > ago(24h)
3 | where ActivityStatusValue in ("Success", "Succeeded")
4 | summarize count() by OperationNameValue, ActivityStatusValue
5 | order by count_ desc
6 | take 20

```

Requête de reconnaissance initiale exécutée avant de construire la règle de détection. Permet d'identifier les valeurs exactes de `ActivityStatusValue` dans l'environnement (certains tenants utilisent "Success", d'autres "Succeeded") et de cibler les opérations Azure les plus fréquentes pour affiner la liste de détection.

KQL-6.2 — Détection d'opérations sensibles (règle principale)

```
1 let operations_sensibles = dynamic([
2     "Microsoft.Authorization/roleAssignments/write",
3     "Microsoft.Authorization/roleAssignments/delete",
4     "Microsoft.Compute/virtualMachines/delete",
5     "Microsoft.KeyVault/vaults/delete",
6     "Microsoft.Network/networkSecurityGroups/write",
7     "Microsoft.Resources/subscriptions/resourceGroups/delete"
8 ]);
9 AzureActivity
10 | where TimeGenerated > ago(1h)
11 | where ActivityStatusValue in ("Success", "Succeeded")
12 | where OperationNameValue in (operations_sensibles)
13 | extend
14     Appelant = Caller,
15     Operation = OperationNameValue,
16     RessourceCible = ResourceId,
17     GroupeRessource = ResourceGroup
18 | extend RaisonAlerte = case(
19     Operation contains "roleAssignments", "Modification de role RBAC",
20     Operation contains "delete", "Suppression de ressource critique",
21     Operation contains "networkSecurityGroups", "Modification regle reseau",
22     "Operation sensible detectee"
23 )
24 | project TimeGenerated, Appelant, Operation, RessourceCible,
25     GroupeRessource, RaisonAlerte, SubscriptionId
26 | order by TimeGenerated desc
```

Adaptation de la règle initialement basée sur SigninLogs (non disponible) vers AzureActivity. Filtre les opérations critiques via une liste `dynamic()` et enrichit chaque ligne avec une `RaisonAlerte` calculée via `case()` pour faciliter le triage SOC sans analyse manuelle supplémentaire.

KQL-6.3 — Validation des alertes générées

```
1 SecurityAlert
2 | where AlertName contains "Operation Azure sensible"
3 | project TimeGenerated, AlertName, AlertSeverity, Entities
4 | order by TimeGenerated desc
5 | take 10
```

Vérifie que la Custom Detection Rule Defender XDR a bien généré des alertes dans la table `SecurityAlert`. Confirme la remontée des alertes depuis Microsoft Defender XDR vers Microsoft Sentinel via la connexion native entre les deux portails.

KQL-6.4 — Validation des incidents générés

```
1 SecurityIncident
2 | where ProductName == "Microsoft 365 Defender"
3 | where Title contains "Operation Azure sensible"
4 | project TimeGenerated, Title, Severity, Status
```

```

5 | order by TimeGenerated desc
6 | take 5

```

Vérifie la création d'incidents dans Sentinel suite aux alertes Defender. Le filtre `ProductName == "Microsoft 365 Defender"` isole spécifiquement les incidents provenant de la connexion Defender XDR → Sentinel, les distinguant des incidents créés directement par les règles analytiques Sentinel.

A.4 SIEM-7 — Détection de l'élévation de privilèges

KQL-7.1 — Exploration des assignations de rôles

```

1 AzureActivity
2 | where TimeGenerated > ago(7d)
3 | where OperationNameValue == "Microsoft.Authorization/roleAssignments/write"
4 | project TimeGenerated, Caller, ResourceId, Properties
5 | order by TimeGenerated desc
6 | take 20

```

Reconnaissance initiale pour identifier les assignations de rôles RBAC existantes et comprendre la structure du champ `Properties` avant de construire la règle. Fenêtre de 7 jours choisie pour maximiser les chances de trouver des exemples dans un environnement de lab à faible activité.

KQL-7.2 — Parsing de la structure JSON de Properties

```

1 AzureActivity
2 | where TimeGenerated > ago(7d)
3 | where OperationNameValue contains "roleAssignments"
4 | extend PropertiesParsed = parse_json(Properties)
5 | project TimeGenerated, Caller, PropertiesParsed
6 | take 5

```

Explore la structure JSON imbriquée du champ `Properties` via `parse_json()`. Indispensable car `roleDefinitionId` et `principalId` ne sont accessibles qu'après parsing — sans cette étape préalable, le filtrage par GUID de rôle RBAC dans la règle principale (KQL-7.3) est impossible.

KQL-7.3 — Détection d'élévation de privilèges RBAC (règle principale)

```

1 let roles_sensibles = dynamic([
2     "8e3af657-a8ff-443c-a75c-2fe8c4bcb635", // Owner
3     "b24988ac-6180-42a0-ab88-20f7382dd24c", // Contributor
4     "18d7d88d-d35e-4fb5-a5c3-7773c20a72d9", // User Access Administrator
5     "62e90394-69f5-4237-9190-012177145e10" // Global Administrator
6 ]);
7 AzureActivity
8 | where TimeGenerated > ago(1h)
9 | where OperationNameValue == "Microsoft.Authorization/roleAssignments/write"
10 | where ActivityStatusValue in ("Success", "Succeeded")
11 | extend PropertiesParsed = parse_json(Properties)

```

```

12 | extend RoleDefinitionId = tostring(PropertiesParsed.roleDefinitionId)
13 | extend RoleDefinitionIdCourt = tostring(split(RoleDefinitionId, "/")[-1])
14 | where RoleDefinitionIdCourt in (roles_sensibles)
15 | extend RoleSensible = case(
16     RoleDefinitionIdCourt == "8e3af657-a8ff-443c-a75c-2fe8c4bcb635", "Owner",
17     RoleDefinitionIdCourt == "b24988ac-6180-42a0-ab88-20f7382dd24c", "Contributor",
18     RoleDefinitionIdCourt == "18d7d88d-d35e-4fb5-a5c3-7773c20a72d9", "User Access
    Administrator",
19     RoleDefinitionIdCourt == "62e90394-69f5-4237-9190-012177145e10", "Global
    Administrator",
20     "Role sensible inconnu"
21 )
22 | project TimeGenerated, Caller, RoleSensible,
23     RessourceCible = ResourceId,
24     GroupeRessource = ResourceGroup, SubscriptionId
25 | order by TimeGenerated desc

```

Adaptation de la règle initialement basée sur AuditLogs. Identifie les assignations de rôles RBAC critiques via leurs GUIDs universels Microsoft (identiques sur tous les tenants Azure). Utilise `split(RoleDefinitionId, "/")[-1]` pour extraire uniquement le GUID depuis le chemin ARM complet avant la comparaison.

KQL-7.4 — Détection d'activité hors heures de travail (règle bonus SIEM-7B)

```

1 AzureActivity
2 | extend Hour = datetime_part("hour", TimeGenerated)
3 | where Hour < 6 or Hour > 22
4 | where ActivityStatusValue in ("Success", "Succeeded")
5 | extend PlageHoraire = case(
6     Hour >= 0 and Hour < 6, "Nuit (00h-06h)",
7     Hour > 22, "Nuit (22h-00h)",
8     "Heure normale"
9 )
10 | extend NiveauRisque = case(
11     OperationNameValue contains "roleAssignments", "Critique",
12     OperationNameValue contains "delete", "Eleve",
13     OperationNameValue contains "write", "Moyen",
14     "Faible"
15 )
16 | project TimeGenerated, Caller, CallerIpAddress,
17     OperationNameValue, PlageHoraire, NiveauRisque,
18     ResourceGroup, ResourceId
19 | order by TimeGenerated desc

```

Règle complémentaire à SIEM-7 : détecte toute opération Azure réussie entre 22h00 et 06h00 UTC. Utilise `datetime_part("hour", TimeGenerated)` pour extraire l'heure de chaque événement. **Note :** le timestamp est en UTC — à ajuster selon le fuseau horaire de l'organisation (+1h pour la France en heure normale).

KQL-7.5 — Corrélation activité sensible + hors horaires

```
1 AzureActivity
2 | extend Hour = datetime_part("hour", TimeGenerated)
3 | where Hour < 6 or Hour > 22
4 | where OperationNameValue in (
5     "Microsoft.Authorization/roleAssignments/write",
6     "Microsoft.Compute/virtualMachines/delete",
7     "Microsoft.KeyVault/vaults/delete"
8 )
9 | project TimeGenerated, Caller, CallerIpAddress, OperationNameValue
10 | order by TimeGenerated desc
```

Requête de corrélation avancée combinant le filtre horaire (SIEM-7B) et le filtre d'opérations sensibles (SIEM-7). Un résultat retourné par cette requête constitue un **double signal de compromission** — élévation de privilège effectuée la nuit — nécessitant une investigation immédiate par l'équipe SOC.

A.5 SIEM-8 — Workbook Dashboard de sécurité Azure Activity

KQL-8.1 — KPIs globaux (Section 1 du Workbook)

```
1 AzureActivity
2 | where TimeGenerated {TimeRange}
3 | summarize
4     TotalOperations = count(),
5     OperationsReussies = countif(ActivityStatusValue in ("Success", "Succeeded")),
6     OperationsEchouees = countif(ActivityStatusValue in ("Failed", "Failure")),
7     AppelantUniques = dcount(Caller),
8     RessourcesAffectees = dcount(ResourceId)
```

Agrégation unique produisant 5 indicateurs clés en une seule passe sur la table. Utilise `countif()` pour les comptages conditionnels et `dcount()` pour les cardinalités distinctes — un seul scan de la table suffit pour alimenter les cinq tuiles KPI du Workbook. Le paramètre `{TimeRange}` est injecté dynamiquement par Sentinel.

KQL-8.2 — Timeline réussites vs échecs (Section 2)

```
1 AzureActivity
2 | where TimeGenerated {TimeRange}
3 | summarize
4     Reussies = countif(ActivityStatusValue in ("Success", "Succeeded")),
5     Echouees = countif(ActivityStatusValue in ("Failed", "Failure"))
6     by bin(TimeGenerated, 1h)
7 | order by TimeGenerated asc
```

Agrège les opérations par tranches horaires via `bin(TimeGenerated, 1h)`, produisant un graphique temporel à deux séries. Le paramètre `{TimeRange}` est injecté dynamiquement par le Workbook Sentinel selon le filtre sélectionné par l'utilisateur — aucune modification manuelle de la requête n'est nécessaire lors d'un changement de période.

KQL-8.3 — Top 20 opérations échouées (Section 3)

```
1 AzureActivity
2 | where TimeGenerated {TimeRange}
3 | where ActivityStatusValue in ("Failed", "Failure")
4 | extend OperationCourte = tostring(split(OperationNameValue, "/")[-1])
5 | summarize NombreEchecs = count() by OperationCourte, Caller, ActivityStatusValue
6 | project Operation = OperationCourte,
7 |         Appelant = Caller,
8 |         NombreEchecs,
9 |         StatutEchec = ActivityStatusValue
10 | order by NombreEchecs desc
11 | take 20
```

Utilise `split(OperationNameValue, "/")[-1]` pour raccourcir les noms d'opérations ARM complets (ex : `Microsoft.Authorization/roleAssignments/write` → `write`) et améliorer significativement la lisibilité des libellés dans le tableau du Workbook sans perte d'information.

KQL-8.4 — Opérations sensibles enrichies (Section 4)

```
1 AzureActivity
2 | where CategoryValue == "Administrative"
3 | where ActivityStatusValue == "Success"
4 | where OperationNameValue has_any (
5 |     "roleAssignments", "roleDefinitions", "networkSecurityGroups"
6 | )
7 | or OperationNameValue endswith "/delete"
8 | summarize Count=count() by Caller, OperationNameValue, bin(TimeGenerated, 1h)
9 | order by Count desc
10 | take 12
```

Approche affinée par rapport à la liste `dynamic()` initiale : filtre d'abord par `CategoryValue == "Administrative"` (taxonomie native Azure) puis par mots-clés via `has_any()`. Plus robuste car indépendant des noms exacts d'opérations qui peuvent varier selon les versions d'API Azure, et réduit significativement le bruit par rapport à un filtre textuel simple.

KQL-8.5 — Top 15 appelants avec taux d'échec (Section 5)

```
1 AzureActivity
2 | where TimeGenerated {TimeRange}
3 | where isnotempty(Caller)
4 | summarize
5 |     TotalActions = count(),
6 |     ActionsReussies = countif(ActivityStatusValue in ("Success", "Succeeded")),
7 |     ActionsEchouees = countif(ActivityStatusValue in ("Failed", "Failure")),
8 |     TypesOperations = dcount(OperationNameValue),
9 |     DerniereAction = max(TimeGenerated)
10 | by Caller
11 | extend TauxEchec = round((ActionsEchouees * 100.0) / TotalActions, 1)
12 | order by TotalActions desc
13 | take 15
```

Calcule un taux d'échec par appelant via `round((ActionsEchouees * 100.0) / TotalActions, 1)`. La multiplication par 100.0 (float) plutôt que 100 (int) est **syntactiquement essentielle** pour éviter la division entière qui retournerait systématiquement 0 pour tout taux inférieur à 100%, faussant l'indicateur de risque.

KQL-8.6 — Distribution IP sources (Section 6)

```
1 AzureActivity
2 | where TimeGenerated {TimeRange}
3 | where isnotempty(CallerIpAddress)
4 | summarize
5     NombreOperations = count(),
6     Echecs            = countif(ActivityStatusValue in ("Failed", "Failure")),
7     AppellantUniques = dcount(Caller)
8     by CallerIpAddress
9 | extend TauxEchec = round((Echecs * 100.0) / NombreOperations, 1)
10 | order by NombreOperations desc
11 | take 100
```

Agrège l'activité par adresse IP source avec calcul du taux d'échec. `isnotempty(CallerIpAddress)` filtre les lignes sans IP — correspondant aux opérations système internes Azure ne possédant pas d'adresse source — pour n'afficher que les activités avec une origine réseau identifiable.

KQL-8.7 — Incidents actifs triés par sévérité (Section 7)

```
1 SecurityIncident
2 | where TimeGenerated {TimeRange}
3 | where Status != "Closed"
4 | extend OrdreTriSeverite = case(
5     Severity == "High",    1,
6     Severity == "Medium",  2,
7     Severity == "Low",     3,
8     4
9 )
10 | summarize NombreIncidents = count()
11     by Severity, Status, Title, OrdreTriSeverite
12 | order by OrdreTriSeverite asc
```

Utilise une colonne calculée `OrdreTriSeverite` (entier 1–4) pour trier les incidents par criticité décroissante, car le tri alphabétique natif sur `Severity` produirait un ordre incorrect (H→L→M au lieu de H→M→L). La colonne est ensuite masquée dans le Workbook via le `formatter: 5` du JSON de configuration.

A.6 SIEM-9 — Playbook SOAR : Notification Slack sur incident High

KQL-9.1 — Vérification des incidents High disponibles

```
1 SecurityIncident
2 | where Severity == "High"
3 | where TimeGenerated > ago(7d)
4 | project TimeGenerated, Title, Severity, Status
5 | take 5
```

Prérequis avant déploiement du Playbook : confirme la présence d'incidents High dans Sentinel pour valider que la Logic App aura des données à traiter lors du test end-to-end. Si aucun résultat, forcer l'exécution d'une règle analytique via « **Run now** » pour générer un incident de test.

KQL-9.2 — Validation d'exécution du Playbook

```
1 AzureActivity
2 | where OperationNameValue contains "Microsoft.Logic/workflows/runs"
3 | where ResourceId contains "playbook-siem9-slack-alert"
4 | project TimeGenerated, OperationNameValue, ActivityStatusValue
5 | order by TimeGenerated desc
6 | take 10
```

Vérifie les exécutions de la Logic App directement depuis **AzureActivity** — chaque run du Playbook génère une entrée dans cette table avec le statut de l'exécution. Permet de confirmer les exécutions et diagnostiquer les échecs sans nécessiter l'accès à l'interface Logic Apps dans le portail Azure.

KQL-9.3 — Validation des incidents notifiés

```
1 SecurityIncident
2 | where Title contains "Operation Azure sensible"
3 | where Status != "Closed"
4 | project TimeGenerated, Title, Severity, Status, Labels
5 | order by TimeGenerated desc
6 | take 10
```

Vérifie que le tag "Slack-Notified" a bien été appliqué sur les incidents traités par le Playbook via l'action `11_Tag_Incident_Notified`. La présence du label dans le champ **Labels** confirme la traçabilité complète de la notification dans Sentinel — prouve que le flux automatisé SIEM-9 a été exécuté avec succès.

Annexe B

Glossaire technique

Cette annexe regroupe les principaux termes techniques utilisés dans le rapport et dans la conception de la solution SIEM Cloud-Native.

Terme	Définition
SIEM (Security Information and Event Management)	Système de sécurité qui aide les organisations à identifier les menaces et vulnérabilités potentielles avant qu'elles ne perturbent l'activité, en détectant les comportements anormaux et en s'appuyant sur l'intelligence artificielle pour automatiser une partie des processus de détection et de réponse aux incidents.
SOAR (Security Orchestration, Automation, and Response)	Ensemble de technologies permettant d'orchestrer, d'automatiser et de coordonner la réponse à un incident de sécurité, en s'appuyant sur des Playbooks déclenchés automatiquement lors de la détection d'une alerte.
Microsoft Sentinel	Solution SIEM cloud-native offrant une sécurité évolutive et économique dans des environnements multicloud et multiplateformes, combinant intelligence artificielle, automatisation et renseignement sur les menaces pour la détection, l'investigation et la réponse aux incidents.
Azure Monitor / Log Analytics Workspace	Service Azure de collecte, d'agrégation et de stockage centralisé des journaux et métriques ; le Log Analytics Workspace constitue le point d'ingestion unique interrogeable en KQL.
KQL (Kusto Query Language)	Langage de requête utilisé pour explorer les journaux stockés dans Log Analytics et construire les règles de détection ainsi que les visualisations des Workbooks.
Analytics Rule (règle d'analyse)	Règle planifiée exécutant une requête KQL selon une fréquence donnée, générant un incident Sentinel lorsqu'elle se déclenche.

Terme	Définition
Workbook	Tableau de bord interactif de Sentinel, alimenté par des requêtes KQL, permettant de visualiser la posture de sécurité, par exemple les connexions échouées ou les incidents par sévérité.
Playbook	Workflow d'automatisation construit sur Azure Logic Apps, déclenché par une Automation Rule Sentinel et exécutant des actions de remédiation ou de notification.
Azure Logic Apps	Moteur d'orchestration cloud utilisé par Sentinel pour exécuter les Playbooks SOAR.
RBAC (Role-Based Access Control)	Modèle de contrôle d'accès basé sur les rôles, utilisé pour restreindre l'accès au Log Analytics Workspace à l'équipe sécurité.
Managed Identity	Identité gérée nativement par Azure, permettant à une ressource, par exemple une Logic App, d'authentifier ses appels à d'autres services comme Microsoft Graph sans gérer de secret.
Watchlist	Liste d'exclusion utilisée dans Sentinel pour filtrer, lors de la détection, les adresses IP ou comptes de service légitimes et réduire les faux positifs.
Threat Intelligence (TI)	Flux de renseignement sur les menaces intégré nativement à Sentinel, utilisé notamment pour identifier les adresses IP malveillantes connues.
Ingestion Delay (délai d'ingestion)	Délai, pouvant atteindre 15 à 30 minutes pour les journaux Azure AD, entre la survenue d'un événement et sa disponibilité dans Log Analytics.
Epic / User Story	Unités du backlog agile : l'Epic regroupe un ensemble cohérent de fonctionnalités, par exemple « Automatisation SOAR », et se décline en User Stories décrivant un besoin précis avec ses critères d'acceptation.

TABLE B.1 – Glossaire technique du projet SIEM Cloud-Native